

Executive summary: ACME Corp

Cloud posture, Kubernetes risk, VM vulnerabilities and compliance across 2 AWS accounts and 2 clusters



Prepared by AccuKnox

September 15, 2026 · Assessment window Sep 1 – Sep 15, 2026



2

AWS accounts scanned



7.97K

Cloud findings



2

Clusters onboarded



16.9K

Kubernetes findings



108K

Image CVE findings



37

Compliance frameworks

TEN SECTIONS

What this executive summary covers

01

Platform Overview

AccuKnox Code to Cognition™ CNAPP



06

VM & Runtime Protection

App behaviour, alerts, VM CVEs



02

CSPM Assessment

AWS asset inventory & findings



07

Investigation Report

AI-correlated deep dives



03

CSPM Key Findings

Public RDS, open admin ports, backups



08

Risk Prioritization

872 findings to a 360-item queue



04

Compliance Insights

37 frameworks, CIS gap deep dive



09

Assistive Remediation

Ask AI & Agent Z



05

KSPM & Key Findings

Clusters, RBAC, images & CIS



10

POC Summary & Next Steps

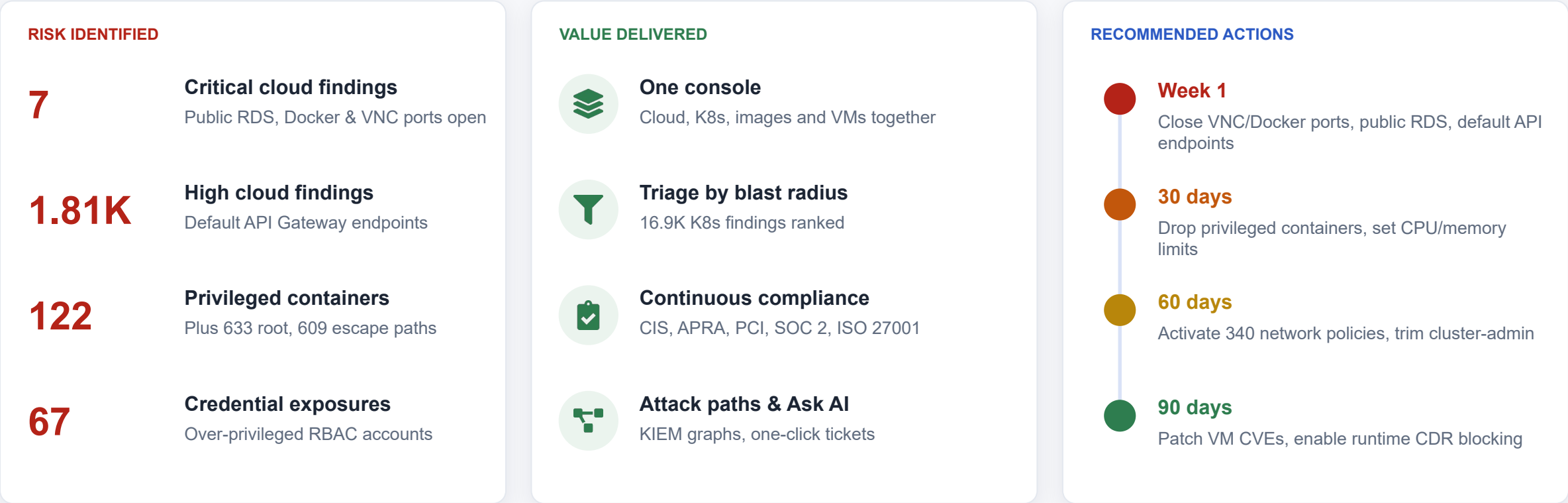
What we proved & the roadmap



Executive Summary

KEY OUTCOMES

Two AWS accounts and two clusters assessed, Sep 1 – Sep 15, 2026



POC Scope & Coverage

EVALUATION SCOPE

What was assessed across the ACME Corp cloud and Kubernetes estate



Amazon Web Services

Sep 1 – Sep 15, 2026



Account · acme-prod
111122223333
7.76K findings



Account · acme-security
444455556666
0.21K findings



eks-stage-133
EKS

62
nodes

156
workloads

127
namespaces



vm-onboarding
VM cluster

9
nodes

9
workloads

1
namespace

ASSESSMENT CATEGORIES



CSPM
AWS misconfigurations



KSPM
Cluster & workload hardening



KIEM
RBAC attack paths



Container scanning
108K ECR image CVEs



VM vulnerability
Linux CVEs & STIG



Runtime protection
Behaviour & enforcement



Compliance
37 frameworks scored



Ask AI & Agent Z
Assisted remediation

SECTION ONE

01

Platform Overview

AccuKnox Code to Cognition™ CNAPP

Learn more: help.accuknox.com/getting-started/accuknox-arch/

- 01 CSPM, KSPM, KIEM, CWPP & container security in one console
- 02 Compliance scored across 37 frameworks
- 03 Ask AI remediation with one-click tickets

PLATFORM

One platform across the cloud, Kubernetes and workload lifecycle



SECTION TWO

02

CSPM Assessment

Cloud asset inventory & findings on AWS

Learn more: help.accuknox.com/how-to/playbook-cspm/

- 01 7.97K findings across 2 AWS accounts
- 02 Inventory by category: Networking, IAM, CDN/DB
- 03 Top misconfigurations: public RDS, admin ports, API endpoints

Cloud Security Executive Dashboard

CSPM AT A GLANCE

2 AWS accounts · 7.97K findings · Sep 1 – Sep 15, 2026

7.97K

Total findings

7

Critical

1.81K

High

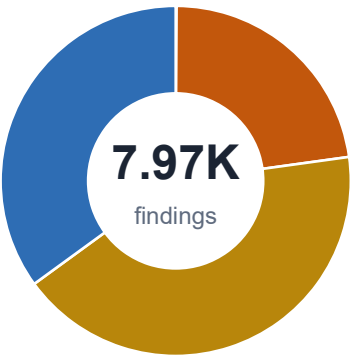
3.36K

Medium

2.79K

Low

FINDINGS BY SEVERITY



Critical	7
High	1.81K
Medium	3.36K
Low	2.79K

WHERE FINDINGS SIT

97%

of all findings are in account acme-prod

acme-prod 7.76K

acme-security 0.21K

Fixing one account removes almost all cloud risk.

Findings by Cloud Provider ⓘ

7.97K Findings

Cloud Provider	Findings	Severity
 AWS	7.97K 	7 C 1.81K H 3.36K M 2.79K L
 Azure	0 	0 C 0 H 0 M 0 L
 GCP	0 	0 C 0 H 0 M 0 L
 OCI	0 	0 C 0 H 0 M 0 L

Top 10 Cloud Accounts with Most Findings ⓘ

Cloud Account	Findings	Severity
 111122223333	7.76K 	7 C 1.78K H 3.25K M 2.72K L
 444455556666	209 	0 C 35 H 103 M 71 L

AccuKnox platform, findings by cloud & account

CSPM: Top Cloud Findings

PLATFORM EVIDENCE

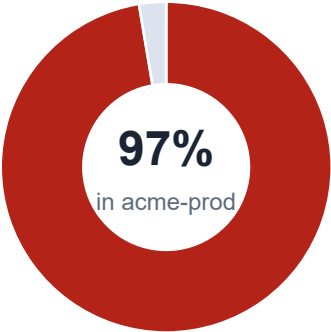
Highest-severity misconfigurations across both AWS accounts

Top 10 Cloud Findings ⓘ

Findings	Severity	Assets
 RDS instance is publicly accessible	 Critical	1
 Security group: sg-0f1e2d3c4b5a69788 (ci-build-sg) has Docker:TCP:2...	 Critical	1
 Security group: sg-0f1e2d3c4b5a69788 (ci-build-sg) has VNC Client:T...	 Critical	1
 Security group: sg-0a1b2c3d4e5f60718 (elb-analytics-gw) has Docker:...	 Critical	1
 Security group: sg-0a1b2c3d4e5f60718 (elb-analytics-gw) has VNC Cli...	 Critical	1

AccuKnox platform, top 10 cloud findings

CONCENTRATION



7.76K of 7.97K findings sit in one account

97%
in acme-prod

All 5 Criticals hit 1 asset each

 **RDS**

Public database

Reachable from any internet host

 **2375**

Docker daemon exposed

Full remote container control

 **5500 / 5900**

VNC wide open

Graphical takeover of hosts

 **RECOMMENDED FIX**

✓

Remove 0.0.0.0/0 inbound on TCP 2375, 5500, 5900

✓

Make RDS private, move to a private subnet

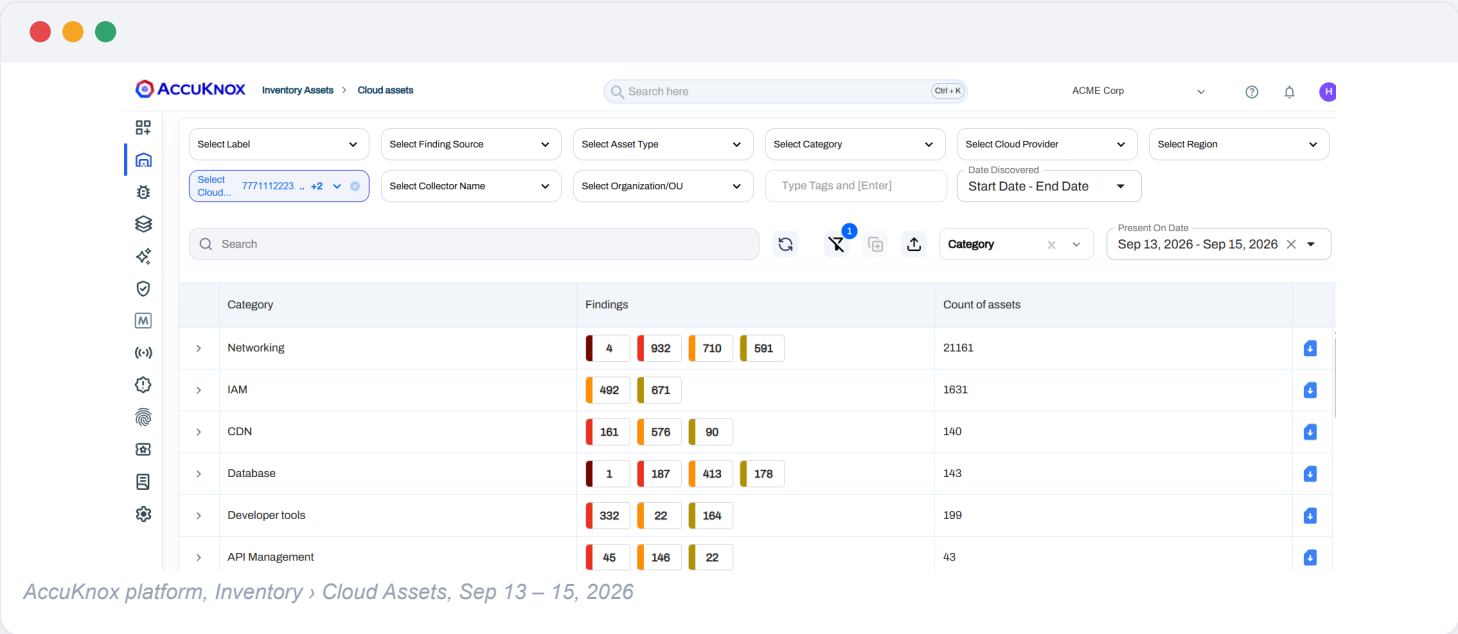
✓

Admin access via VPN or SSM Session Manager

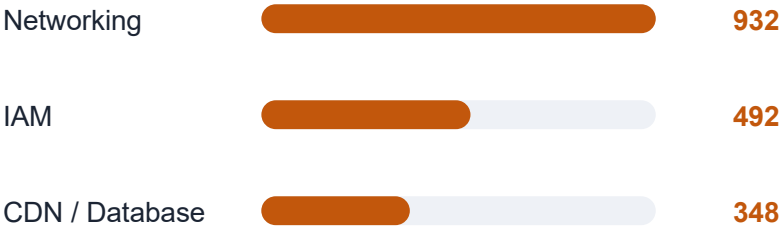
Cloud Asset Inventory by Category

PLATFORM EVIDENCE

Where the 7.97K findings map across asset categories



HIGH-SEVERITY FINDINGS BY CATEGORY



Critical: Networking 4 · CDN/DB 1 (public RDS)

Networking is the largest blast radius; IAM shows permission sprawl.



21,161
Networking assets
4 Critical · 932 High



1,631
IAM assets
492 High · 671 Medium



283
CDN + Database assets
1 Critical · 348 High

SECTION THREE

03

CSPM Key Findings

Public exposure, open admin ports & database access

01 The handful of findings that matter most

02 Live platform evidence for each one

03 Security graph to the real cloud resource

04 A clear, prioritised fix

AWS: VNC Client Port Open to the Public

CRITICAL

PLATFORM EVIDENCE

TCP 5500 (VNC) reachable from 0.0.0.0/0 on elb-analytics-gw

**TCP 5500**
Open to 0.0.0.0/0

12 / 10 days
Open vs critical SLA: breached

**17**
Frameworks impacted

**04/09**
First detected, still active

AccuKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Cloud Findings Risk Factor

Search

Findings

Critical: 5

Last Seen	Finding Name
2026-09-15 08:08:21	RDS instance is pu
2026-09-15 08:08:21	Security group: sg-
2026-09-15 08:08:21	Security group: sg-
2026-09-15 08:08:21	Security group: sg-
2026-09-15 08:08:21	Security group: sg-
2026-09-15 08:08:21	Security group: sg-

Security group: sg-0a1b2c3d4e5f60718 (elb-analytics-gw) has VNC Client:TCP:5500 open to 0.0.0.0/0

Critical

Create Ticket

Ask AI

Age	Severity	SLA	CVE ID	Tickets Created
12 days	Critical	10 days	NA	0

Description

Security Graph

Solution

Check Details

Classification

Remed

Determine if TCP port 5500 for VNC Client is open to the public

Finding for in resource

aws_vpc_security_group | arn:aws:ec2:us-east-1:111122223333:security-group/sg-0a1b2c3d4e5f60718

First detected about 11 days ago, on 04/09/2026

Last detected today, on 15/09/2026

Compliance Frameworks

AWS CIS Benchmark v4.0.1

BAIT

CMMC - Cybersecurity Maturity Model Certification

CSCRF SEBI

FERPA

FISMA

HITRUST CSF

ISO 27001 - 2013

ISO 27001 - 2022

LGPD

NIST 800-171

NIST CSF

NIST SP 800-53

PCI

RBI CSF (Cyber Security Framework) for UCBS

SOC 2 Type II

VAIT

Asset

elb-analytics-gw

Asset Type

aws_vpc_security_group

Status

Active

Ignored

No

Location

us-east-1

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT

**Remote desktop takeover**
Any internet host gets graphical control

**SLA already breached**
2 days past the 10-day window

**Compliance hit**
CIS, PCI, SOC 2, ISO 27001, NIST, HITRUST

**RECOMMENDED FIX**

✓ Remove the 0.0.0.0/0 rule on sg-0a1b2c3d4e5f60718

✓ Scope access to VPN or corporate CIDR

✓ Prefer SSM Session Manager over VNC

AWS: API Gateway on Default Endpoint

HIGH

PLATFORM EVIDENCE

execute-api default endpoint enabled on stage-token-api



execute-api

Default endpoint enabled

13 / 15 days

Open vs SLA: 2 days left



2

Frameworks: PCI, SAMA



1.81K

High cloud findings overall

AccuKnox platform, live finding evidence

The screenshot displays the AccuKnox platform interface. On the left, there's a sidebar with navigation icons. The main area shows a finding titled "API Gateway 'stage-token-api' is accessible through default endpoint" with a severity of "High". The finding details include a description, asset information, and compliance frameworks. The finding is categorized as "High" and has a severity of "High". The finding is categorized as "High" and has a severity of "High".

RISK IMPACT



Bypasses domain controls

Skips custom-domain WAF, auth & throttling



Unauthenticated vector

Anyone with the API ID reaches it



Regulatory gap

Mapped to PCI and SAMA CSF



RECOMMENDED FIX

- ✓ Disable default endpoint on stage-token-api & sandbox-api
- ✓ Route via custom domain behind WAF + authorizer
- ✓ Re-scan to confirm closure

Security Graph: VNC Attack Path

CRITICAL

SECURITY GRAPH

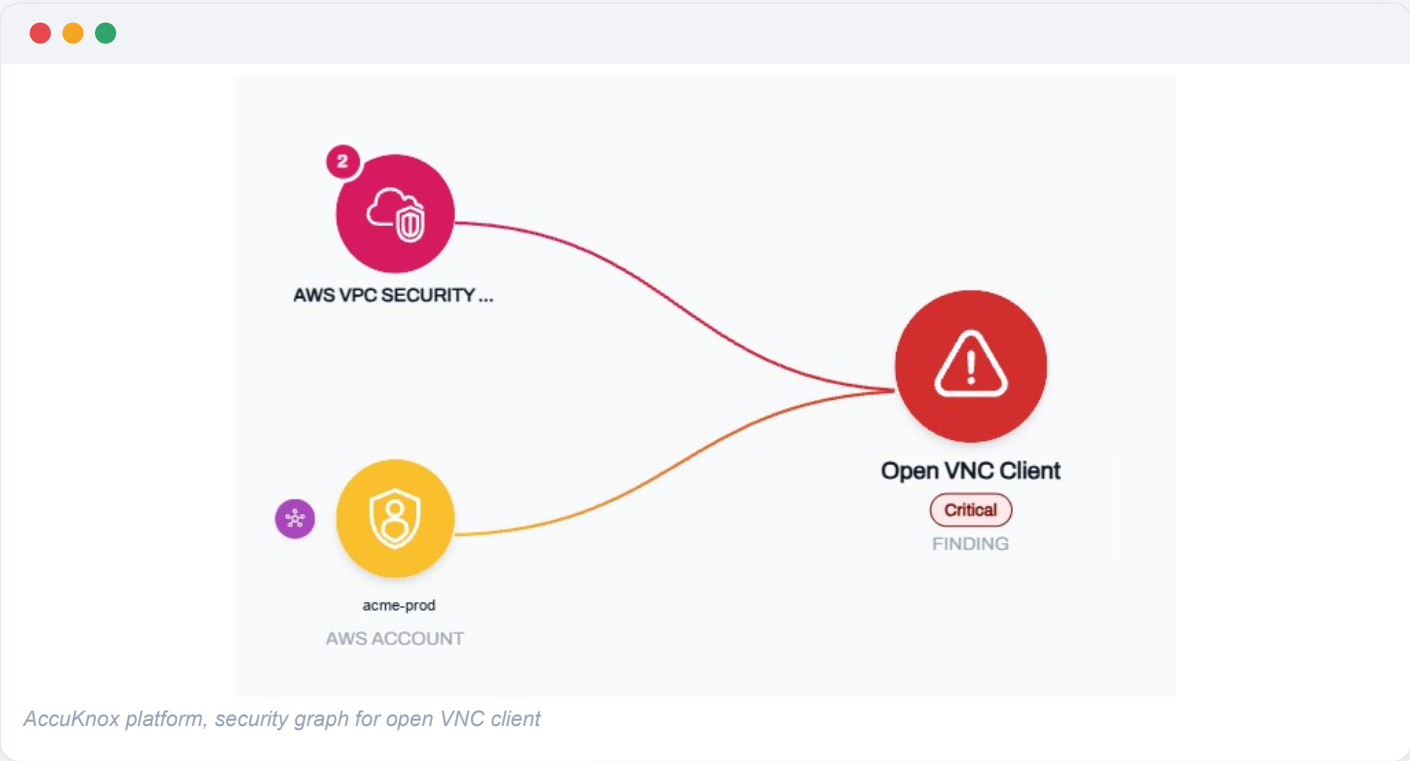
How the open VNC finding connects to accounts and security groups

**2**
Security groups feed it

**1**
Account: acme-prod, us-east-1

**3**
Ports exposed: 2375, 5500, 5900

**Chained**
VNC + Docker exposure



RISK IMPACT

- **Two contributing groups**
elb-analytics-gw & ci-build-sg
- **Single-account blast radius**
All paths converge on acme-prod
- **Chained with Docker**
VNC foothold + container control

**RECOMMENDED FIX**

- ✓ Treat both groups as one remediation unit
- ✓ Strip 0.0.0.0/0 from 2375, 5500, 5900
- ✓ Re-run the graph to confirm it clears

AWS: RDS Instance Publicly Accessible

CRITICAL

PLATFORM EVIDENCE

data-lake-metastore-rr open to the internet



Public

Reachable from any host

12 / 10 days

Open vs critical SLA: breached



23

Frameworks impacted



0

Tickets created

ACCUKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Cloud Findings Vulnerability Nav

Q Search

Findings

Open Docker: us-east-1: 2

Open VNC Client: us-east-1: 2

RDS Publicly Accessible: us-east-1: 1

Last Seen Finding Name

2026-09-15 08:08:21 RDS instance is pu

1-1 of 1

1 row selected 1-3 of 3

RDS instance is publicly accessible Critical

Age 12 days Severity Critical SLA 10 days CVE ID NA Tickets Created 0

Description

Security Graph

Solution

Check Details

Classification

Remed

Ensures RDS instances are not launched into the public cloud

Finding for in resource

aws_rds_db_instance | arn:aws:rds:us-east-1:111122223333:db:data-lake-metastore-rr

First detected

about 11 days ago, on 04/09/2026

Last detected

today, on 15/09/2026

Compliance Frameworks

AWS CIS Benchmark v1.5.0

AWS CIS Benchmark v2.0.0

AWS CIS Benchmark v4.0.1

AWS CIS Benchmark v7.0.0

BAIT

CMMC - Cybersecurity Maturity Model Certification

COPPA

CSCRF SEBI

California Consumer Privacy Act (CCPA)

FERPA

FISMA

HIPAA

HITRUST CSF

ISMS-P for AWS

ISO 27001 - 2013

ISO 27001 - 2022

Korean Financial Security Agency Guidelines

LGPD

NIST 800-171

NIST CSF

NIST SP 800-53

PCI

RBI CSF (Cyber Security Framework) for UCBs

RBI IT Framework Master Direction

SAMA Cyber Security Framework

+ 2

Create Ticket

Ask AI

Asset

data-lake-metastore-rr

Asset Type

aws_rds_db_instance

Status

Active

Ignored

No

Location

us-east-1

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT



Data lake on the internet

No network boundary in front of it



SLA breaching

2 days past the window, no ticket



23 frameworks violated

CIS, PCI, HIPAA, ISO 27001, NIST, RBI



RECOMMENDED FIX

- ✓ Disable public access, move to a private subnet
- ✓ Allow the app tier only
- ✓ Rotate any credentials exposed meanwhile

Security Graph: RDS Public Access Blast Radius

CRITICAL

SECURITY GRAPH

How the public RDS finding connects to its AWS resource



1

Asset, directly exposed



0

Compensating controls



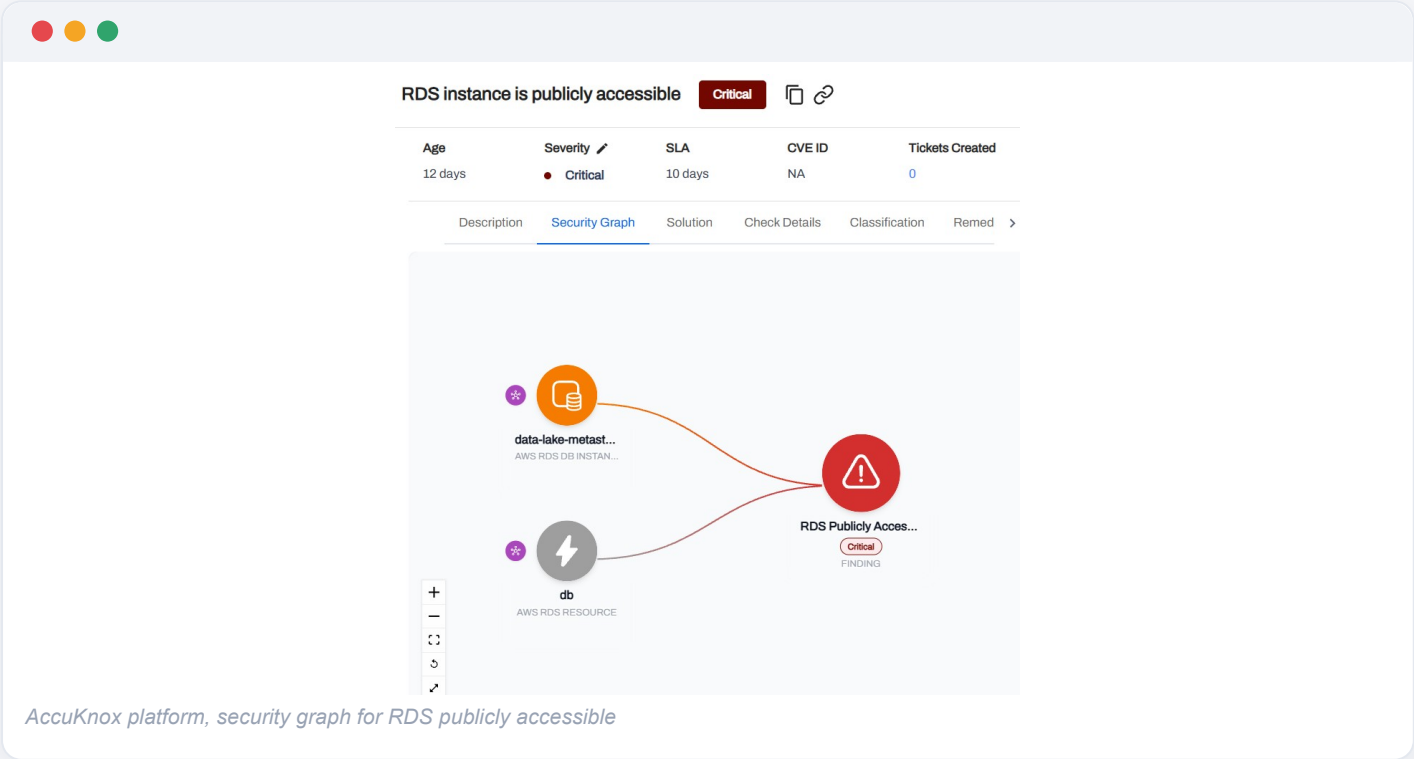
Data lake

Connected metastore



us-east-1

Account acme-prod



RISK IMPACT



Single asset, direct path

Nothing absorbs the risk



Reaches the data lake

Backs a data-lake metastore



No WAF, bastion or proxy

The finding is the whole attack surface



RECOMMENDED FIX

- ✓ Confirm no workload needs public access
- ✓ Set publicly_accessible to false
- ✓ Re-run the graph to verify

AWS: Backup Vault Missing Deletion Protection

HIGH

PLATFORM EVIDENCE

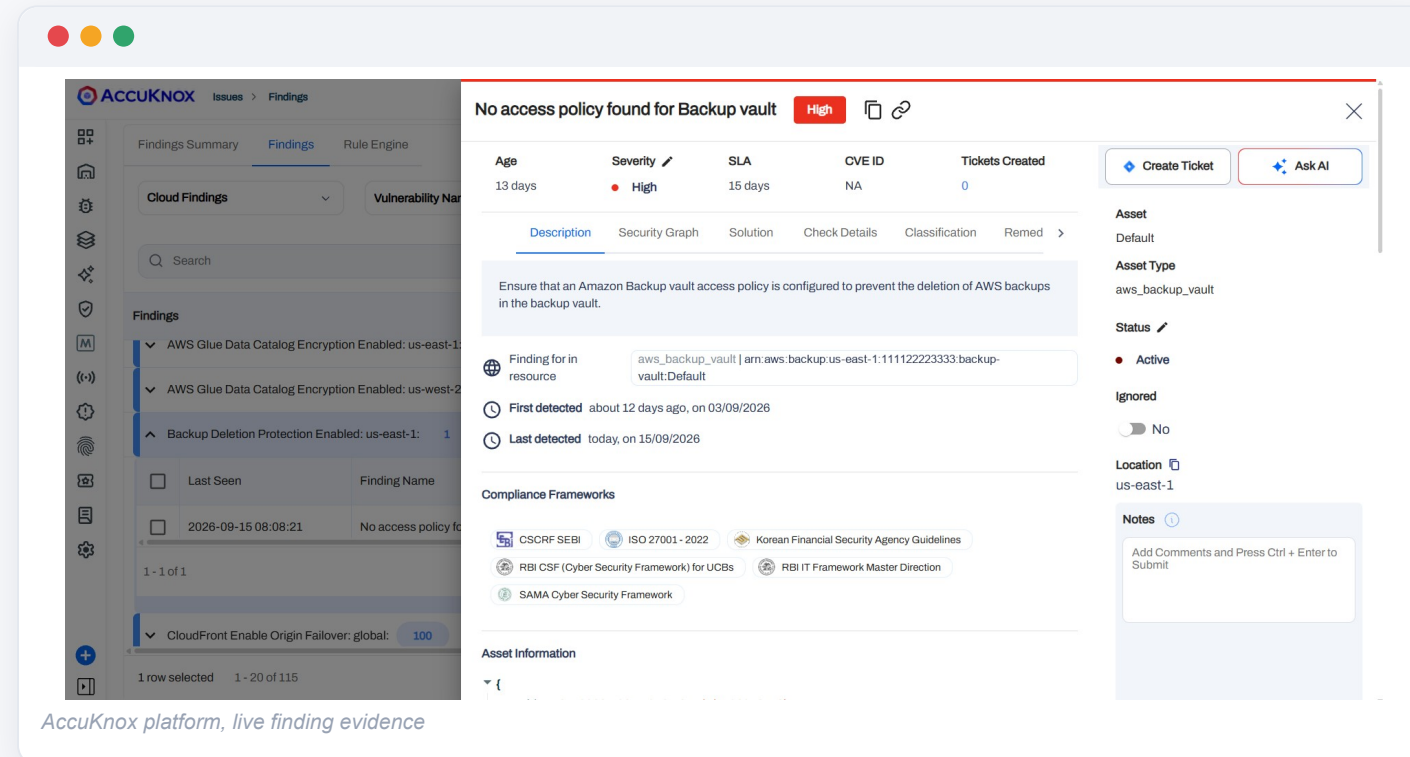
No access policy on the Default AWS Backup vault in us-east-1

 **No policy**
Recovery points deletable

13 / 15 days
Open vs SLA: 2 days left

 **acme-prod**
Same account as public RDS

 **Default**
Vault, us-east-1



The screenshot displays the AccuKnox platform interface. On the left, a sidebar shows navigation options like 'Findings Summary', 'Findings', and 'Rule Engine'. The main panel shows a finding titled 'No access policy found for Backup vault' with a severity of 'High'. The finding details include a description: 'Ensure that an Amazon Backup vault access policy is configured to prevent the deletion of AWS backups in the backup vault.' It also shows the asset 'aws_backup_vault | arn:aws:backup:us-east-1:111122223333:backup-vault:Default', the first detected date 'about 12 days ago, on 03/09/2026', and the last detected date 'today, on 15/09/2026'. The finding is associated with several compliance frameworks, including CSORF SEBI, ISO 27001-2022, Korean Financial Security Agency Guidelines, RBI CSF (Cyber Security Framework) for UCBs, RBI IT Framework Master Direction, and SAMA Cyber Security Framework. The asset information section shows 'Asset: Default' and 'Asset Type: aws_backup_vault'. The status is 'Active'. The location is 'us-east-1'. The finding is listed as '1 - 1 of 1'.

AccuKnox platform, live finding evidence

RISK IMPACT

-  **Backups deletable at will**
No policy stops recovery-point deletion
-  **Ransomware exposure**
One stolen credential wipes every backup
-  **Nearing SLA**
Breaches in 2 days, like the RDS did

-  **RECOMMENDED FIX**
- ✓ Deny DeleteRecoveryPoint & DeleteBackupVault
 - ✓ Allow a break-glass role only
 - ✓ Enable AWS Backup Vault Lock

Security Graph: Backup Vault Deletion Exposure

HIGH

SECURITY GRAPH

How the missing policy connects to the vault and its backups



2
Nodes, one shared path



0
Fallback controls



Same
Account as public RDS



Last line
Of defence, currently open

No access policy found for Backup vault High  

Age	Severity	SLA	CVE ID	Tickets Created
13 days	High	15 days	NA	0

Description

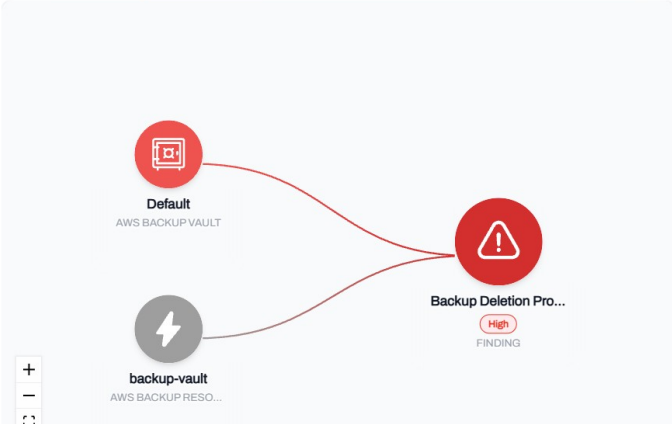
Security Graph

Solution

Check Details

Classification

Remed >



AccuKnox platform, security graph for backup vault

RISK IMPACT

- 

Vault & resource share a path
No secondary control
- 

Compounds the RDS risk
Same account, bigger blast radius
- 

No safety net
The recovery path itself is exposed



RECOMMENDED FIX

✓ Close together with the RDS fix

✓ Stop theft and backup deletion in one pass

SECTION FOUR

04

Compliance Insights

37 frameworks continuously scored

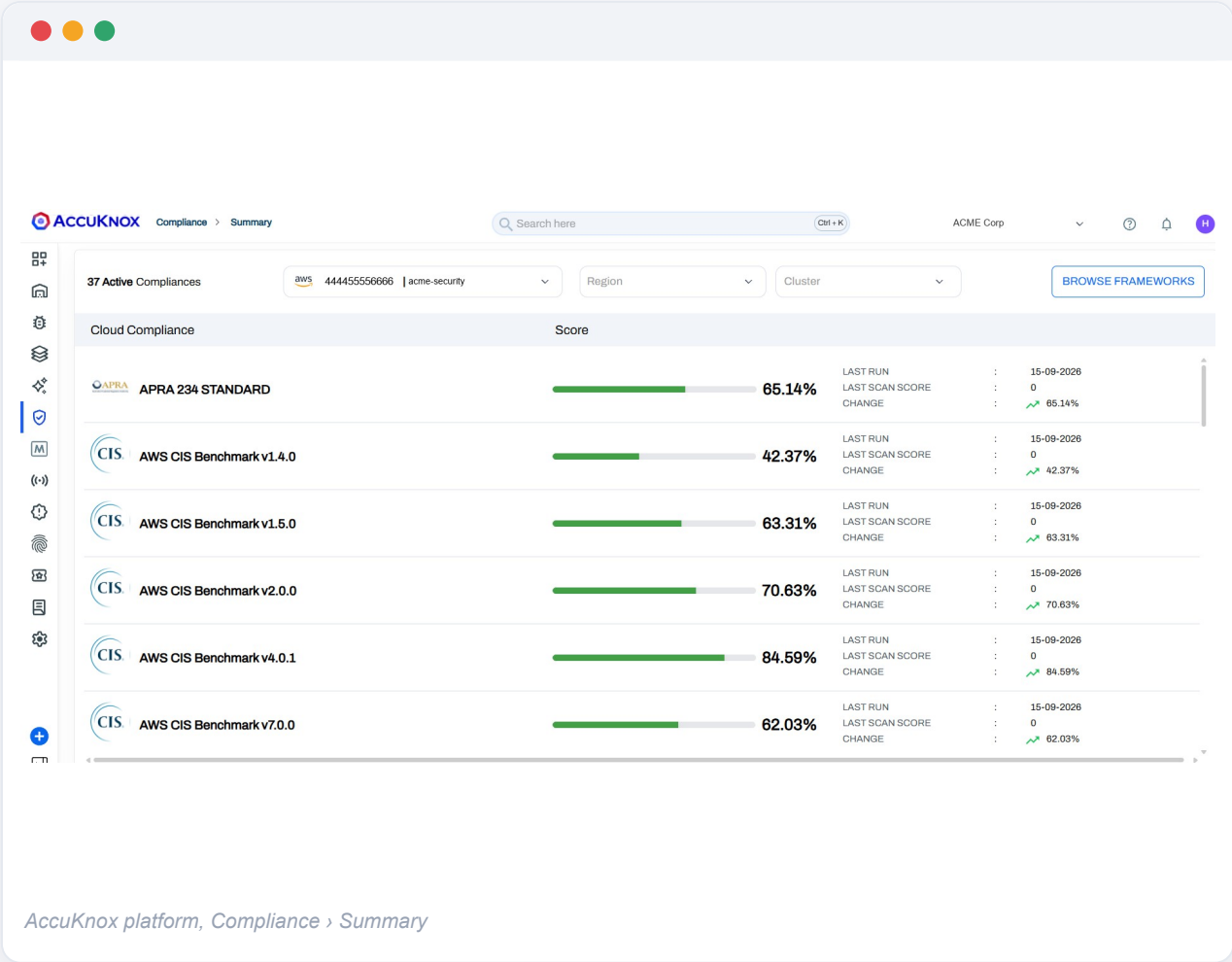
Learn more: help.accuknox.com/use-cases/compliance/

- 01 CIS, APRA, PCI, SOC 2, ISO 27001, NIST
- 02 CIS v4.0.1 leads at 84.6%, v1.4.0 lags at 42.4%
- 03 Wildcard IAM admin drives the lowest score
- 04 Credential hygiene is already strong

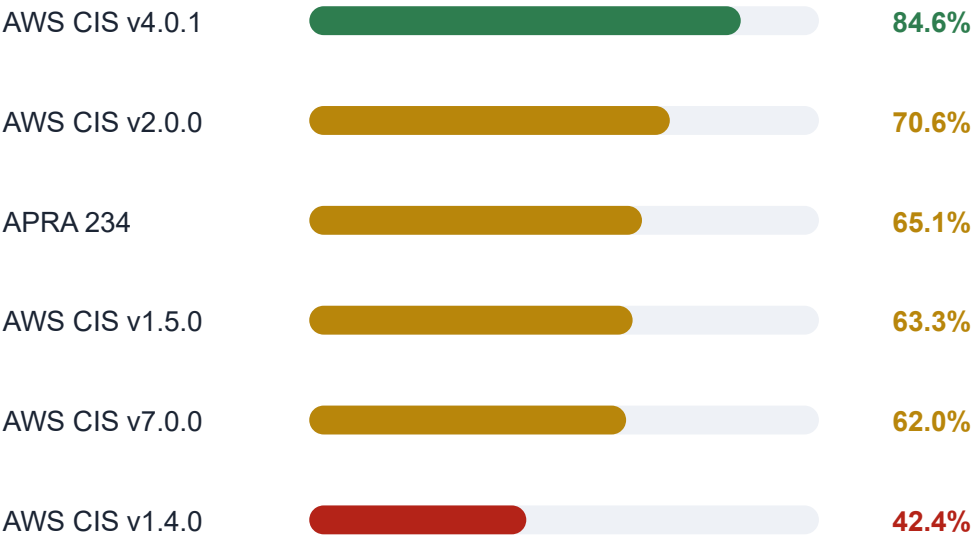
Compliance Coverage at a Glance

PLATFORM EVIDENCE

37 active frameworks scored on account 444455556666 (acme-security), last run 15-09-2026



SCORE BY FRAMEWORK



37

Frameworks scored

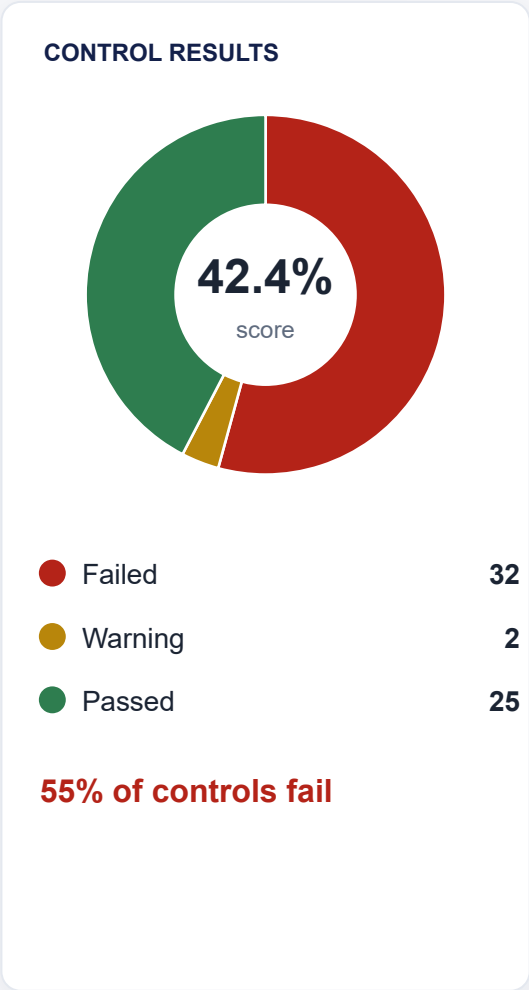
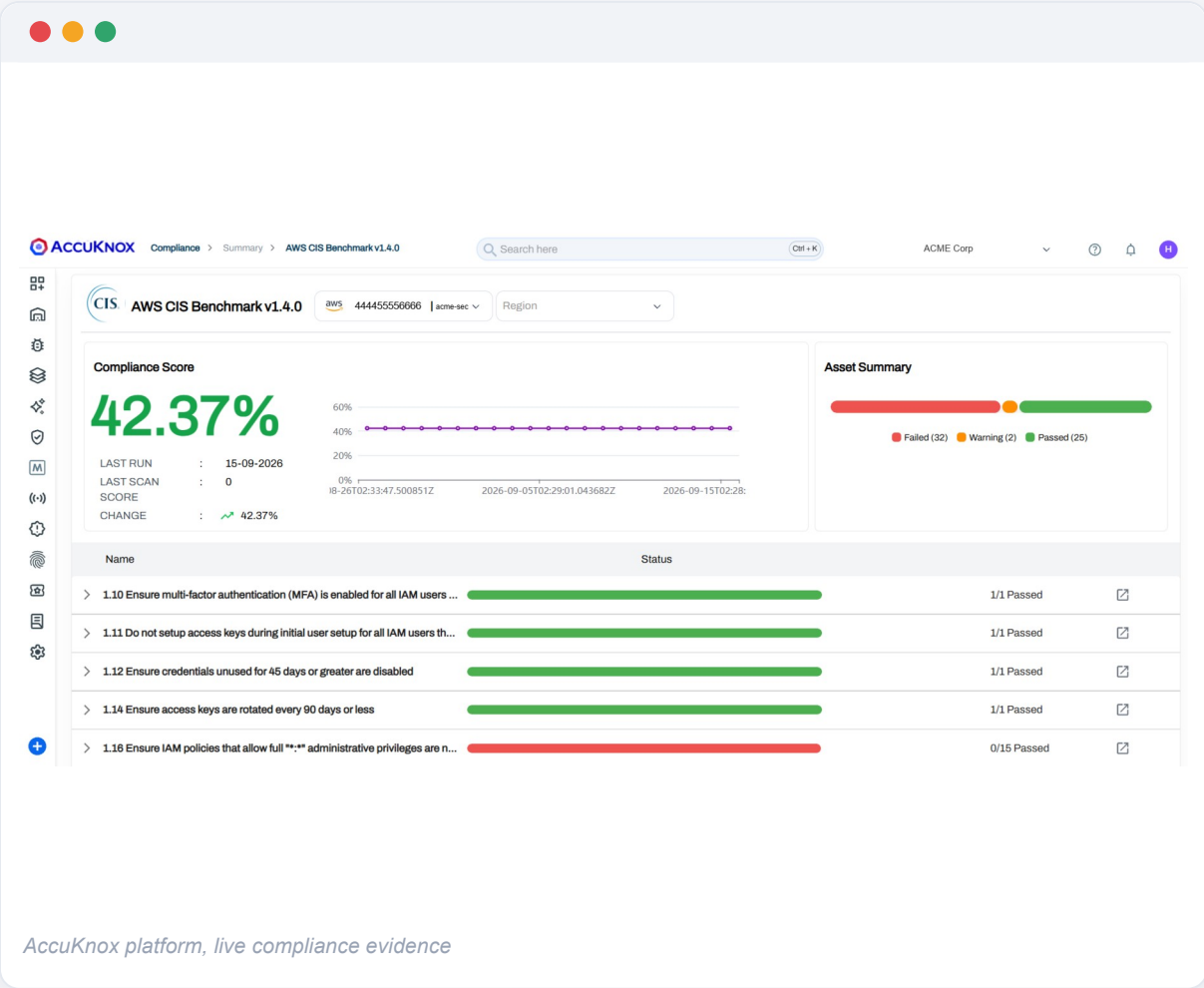


42.4%

Weakest: CIS v1.4.0

PLATFORM EVIDENCE

Score 42.37%, flat for the whole assessment window



WHY IT SCORES LOW

-  **Wildcard admin**
Control 1.16 fails 0/15: "*" policies
-  **Flat all window**
Score held near 42% for 15 days
-  **Auth is strong**
MFA & key rotation (1.10–1.14) pass

 **RECOMMENDED FIX**

- ✓ Replace 15 wildcard IAM policies with scoped ones
- ✓ Re-scan: fixing 1.16 alone lifts the score materially

SECTION FIVE

05

KSPM Assessment & Key Findings

Cluster inventory, risk posture & top findings

Learn more: help.accuknox.com/use-cases/kspm/

- 01 2 clusters, 16.9K findings triaged
- 02 122 privileged, 633 root, 609 escape paths
- 03 KIEM: cluster-admin sprawl & audit tampering
- 04 Image CVEs and CIS benchmark gaps

PLATFORM EVIDENCE

2 clusters onboarded and continuously synced, Sep 1 – Sep 15, 2026

ACCUKNOX

Inventory Assets > Clusters

Search here

Ctrl + K

ACME Corp

Clusters

CLUSTERS NAMESPACES WORKLOADS

+ FILTER

Search

☐	Name	Alerts	Findings	Onboarded	Last Synced	Nodes	Workloads	Namespa...	Active Poli...	Tags
☐	 vm-onboarding	 0	 STIG	26-08-2026 01	15-09-2026 10	9	9	1	2	None
☐	 eks-stage-133	 0	 CK	24-08-2026 21	15-09-2026 10	62	156	127	6	None

Onboard Cluster

AccuKnox platform, Inventory > Clusters



eks-stage-133

EKS · onboarded 24-08-2026

CIS + KSPM + KIEM

62

Nodes

156

Workloads

127

Namespaces

6

Active policies



vm-onboarding

VM · onboarded 26-08-2026

STIG scanning

9

Nodes

9

Workloads

1

Namespace

2

Active policies

Kubernetes Open Findings & Trend

KSPM AT A GLANCE

16.9K open Kubernetes findings on eks-stage-133

16.9K

Open findings

7

Critical

5.7K

High · 34%

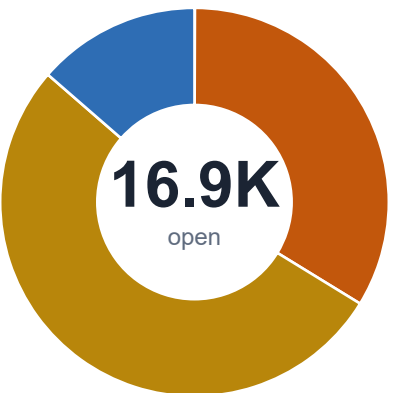
8.9K

Medium · 53%

2.3K

Low · 14%

SEVERITY MIX

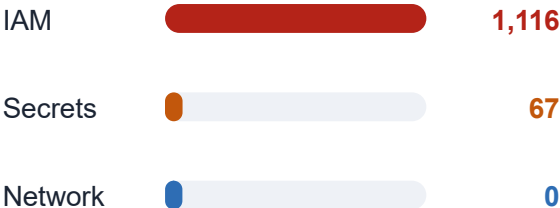


87% of open findings are High or Medium

IDENTITY IS THE RISK SURFACE

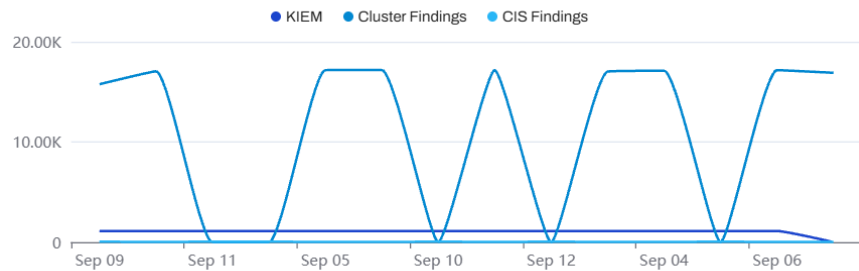
1,116

categorised findings are IAM



Identity, not network, drives Kubernetes risk here.

K8s Findings Trend



AccuKnox platform, K8s findings trend

Policy Coverage & Findings by Asset Type

PLATFORM EVIDENCE

The cluster is fully observed but essentially unenforced

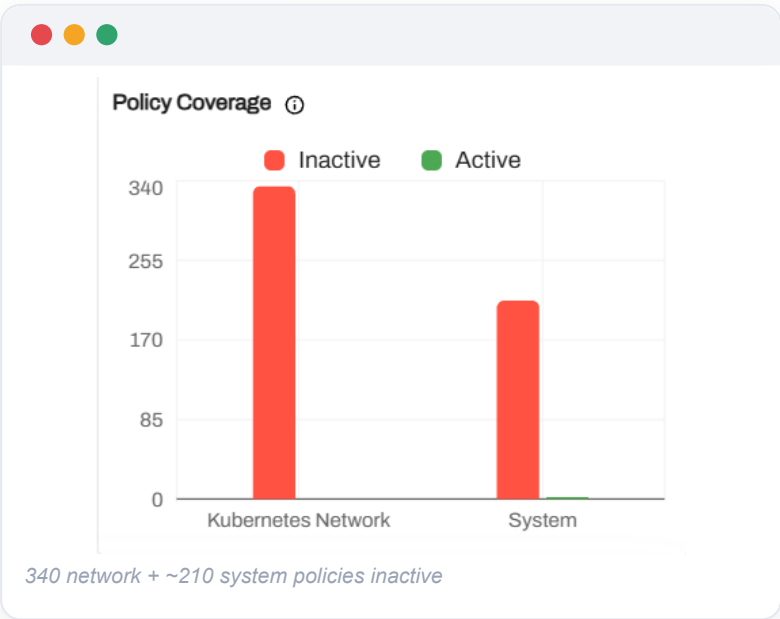
POLICY COVERAGE

~550

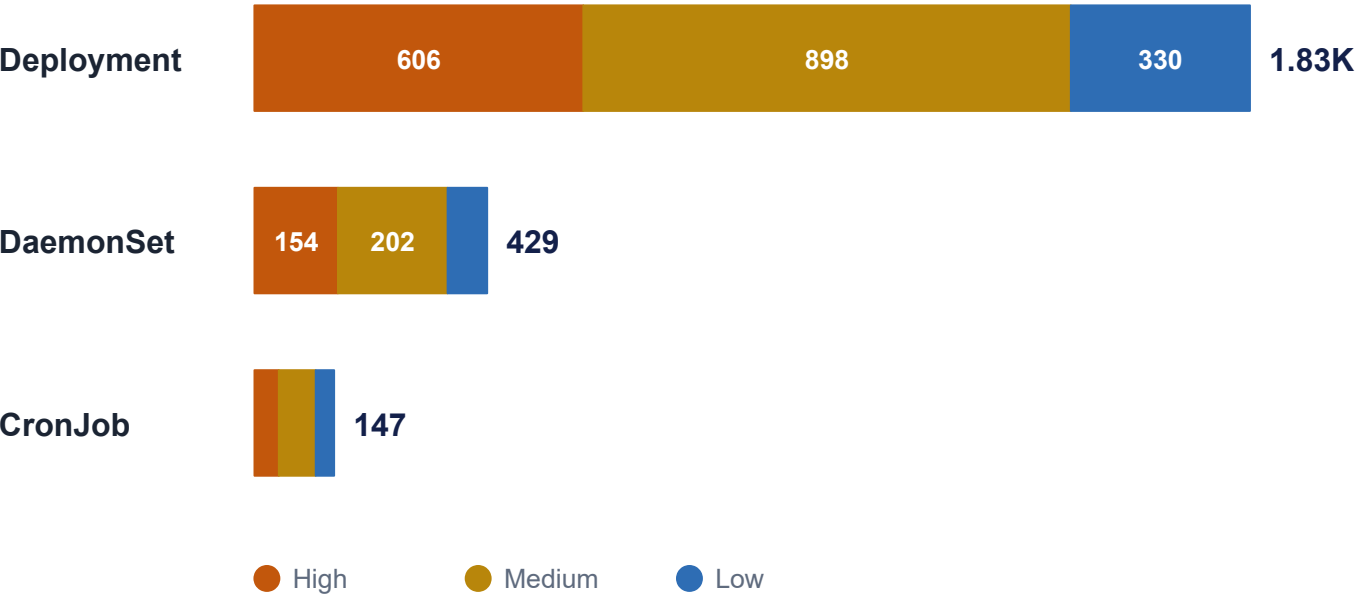
policies sit inactive

< 5

policies active



CLUSTER FINDINGS BY ASSET TYPE



1.83K findings live in Deployments: fixing a few workload templates clears risk at scale.

PLATFORM EVIDENCE

Runtime and configuration risk indicators on eks-stage-133

609

Container-escape paths

536

hostPath mounts

122

Privileged containers

633

Containers run as root

67

Credential exposures

4

Internet-reachable workloads

K8s Risk Posture ⓘ

6	67	4	122	633	536
Over-Privileged Service Account	Credential Exposure	Internet Exposure	Privileged Container	Root Containers	HostPath Mount
5	7	119	0	609	0
Insecure Capabilities	Host Network Access	Unused Kubernetes Roles	Service Accounts with No Workloads	Container Escape	Reverse Shell
0	0	0	0		
Binary Executions	Unauthorized File Access	Network Violations	Cryptomining		

AccuKnox platform, K8s risk posture

RISK IMPACT

- 

Container escape surface

Host filesystem broadly reachable from pods
- 

Privilege sprawl

Root, privileged & 6 over-privileged SAs



No active runtime attacks detected

0 Reverse shells

0 Binary exec

0 File access

0 Network

0 Cryptomining

Exposure is configuration-based, so it can be fixed before it is exploited.



RECOMMENDED FIX

✓ Remove 122 privileged flags & 536 hostPath mounts

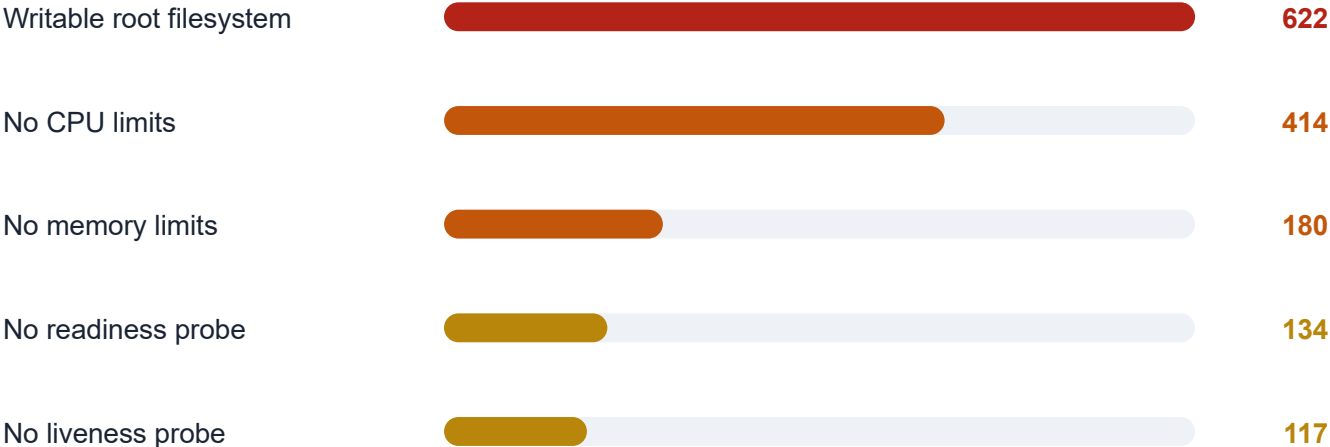
✓ Default to non-root via securityContext

✓ Rotate the 67 exposed credentials

PLATFORM EVIDENCE

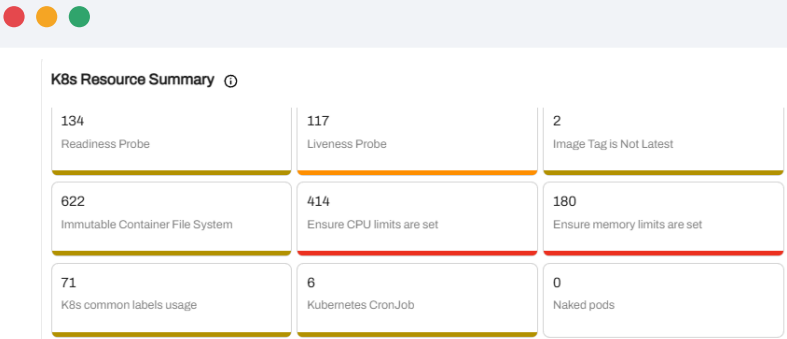
Container and workload health indicators across the cluster

WORKLOAD HYGIENE GAPS



GOOD HYGIENE ALREADY IN PLACE

0 Naked pods **2** Unpinned images **6** CronJobs to review



AccuKnox platform, K8s resource summary

RISK IMPACT



Noisy-neighbour risk

One pod can starve a node

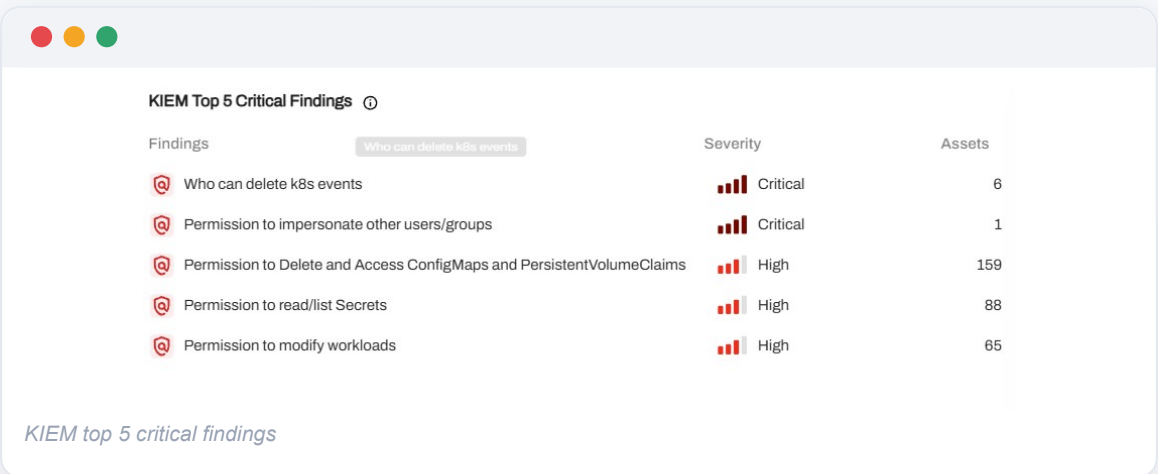
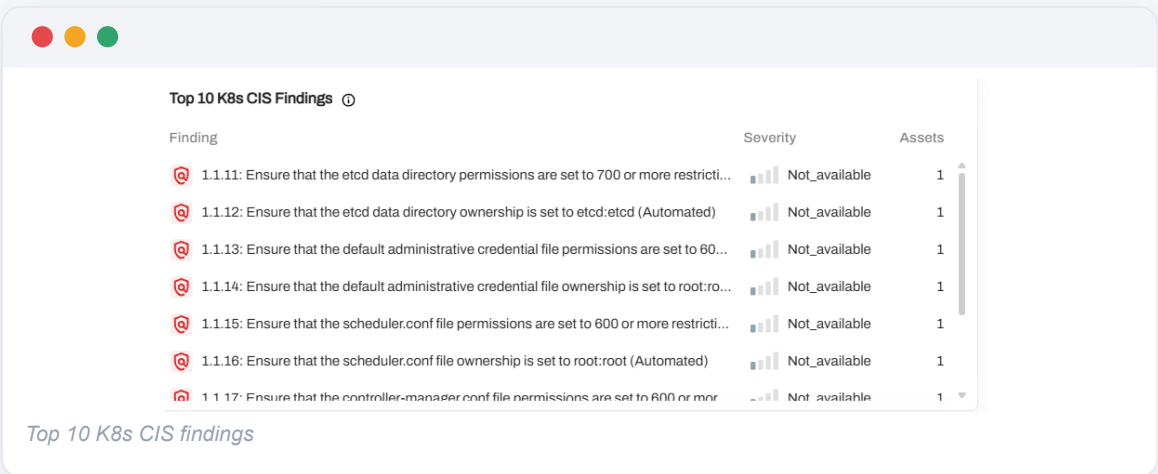


RECOMMENDED FIX

- ✓ readOnlyRootFilesystem + CPU/memory limits
- ✓ Set once in base templates

PLATFORM EVIDENCE

Control-plane file permissions and RBAC entitlement risks



CONTROL-PLANE FILE HYGIENE



etcd data dir



scheduler.conf

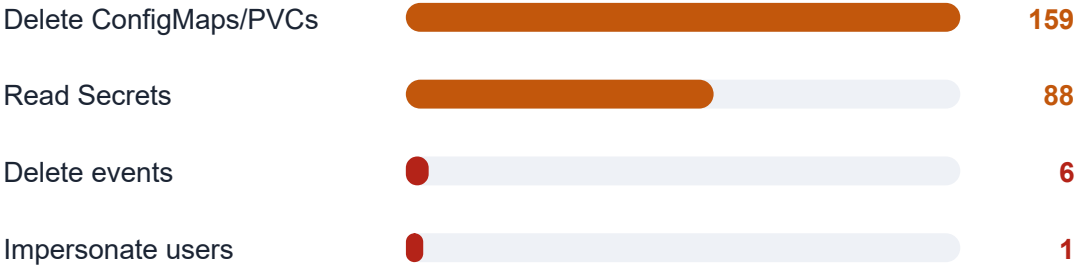


controller-manager.conf

CIS 1.1.11 – 1.1.17 · one asset each

Fix: chmod 600/700 · chown root:root

IDENTITIES WITH RISKY RBAC VERBS



Delete events + impersonate = act as someone else and erase the trail

Kubernetes: Privileged Container (DaemonSet)

HIGH

PLATFORM EVIDENCE

eks-stage-dcgm-exporter running privileged, control C-0057



privileged

Host devices & kernel caps

22 / 15 days

Open vs SLA: breached



62

Nodes exposed via DaemonSet



C-0057

Control ID

ACCUKNOX

Issues > Findings

Findings SummaryFindingsRule Engine

Cluster FindingsAsset Type

Search

Findings

- k8s_security_CronJob45
- k8s_security_DaemonSet141

Last SeenVulnerability Name

2026-09-09 01:15:33	Privileged container
2026-09-09 01:15:33	ServiceAccount token
2026-09-09 01:15:33	HostPath mount

1 row selected1 - 14 of 14

Privileged containerHigh

Age15 daysSeverityHighSLA15 daysCVE IDC-0057Tickets Created0

Create TicketAsk AI

DescriptionSolutionClassificationResource ManifestRaw Information

Potential attackers may gain access to privileged containers and inherit access to the host resources. Therefore, it is not recommended to deploy privileged containers unless it is absolutely necessary. This control identifies all the privileged Pods.

Finding for in resourcek8s_security_DaemonSet | k8s_security_DaemonSet

First detectedabout 22 days ago, on 24/08/2026

Last detectedabout 7 days ago, on 08/09/2026

Asset Information

```
{  "id": "f3a0c4d0-62f9-4f70-a82f-5f92290dboda"  "asset": {    "id": "2a9ae5cf-db84-4508-8dff-842c51d8826f"    "name": "eks-stage-dcgm-exporter"    "type": {      "id": "579dd438-eb69-4086-9434-b05c94191005"      "name": "k8s_security_DaemonSet"      "category": "Workload"    }  }}
```

Asset

eks-stage-dcgm-exporter

Asset Type

k8s_security_DaemonSet

Status

Active

Ignored

No

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT



Pod compromise = node

Inherits host devices & kernel



Cluster-wide blast radius

DaemonSet runs on all 62 nodes



Past its SLA

First seen 24/08/2026, still active



RECOMMENDED FIX

- ✓ Remove privileged: true from dcgm-exporter
- ✓ Grant only needed capabilities
- ✓ Use a device plugin for GPU access

Container Image Scan: Critical CVE in curl

CRITICAL

PLATFORM EVIDENCE

CVE-2022-32221 in curl@7.64.0 on an ECR-hosted image



CVE-2022-32221
libcurl use-after-free



7.64.0
Fixed in curl ≥ 7.86.0



108,259
Image findings in total



Live
Production app image

AccuKnox

Issues > Findings

Findings Summary Findings Rule Engine

Container Image Findings

Search

	Last Seen	Identification Number
☐	2026-09-08 02:48:00	CVE-2022-32221, C...
☐	2026-09-08 02:50:30	CVE-2022-32221, C...
☐	2026-09-08 02:49:14	CVE-2022-32221, C...
☒	2026-09-07 02:38:58	CVE-2022-32221, C...
☐	2026-09-07 02:41:48	CVE-2022-32221, C...
☐	2026-09-08 00:12:13	CVE-2022-1650, CW...
☐	2026-09-08 00:17:19	CVE-2022-1650, CW...

1 row selected 1 - 20 of 108259

curl: POST following PUT confusion: (curl@7.64.0-4+deb10u2), CVE-2022-32221

Critical

Create Ticket

Ask AI

Age	Severity	SLA	CVE ID	Tickets Created
1 day	Critical	10 days	CVE-2022-32221	0

Description

When doing HTTP(S) transfers, libcurl might erroneously use the read callback ('CURLOPT_READFUNCTION') to ask for data to send, even when the 'CURLOPT_POSTFIELDS' option has been set, if the same handle previously was used to issue a 'PUT' request which used that callback. This flaw may surprise the application and cause it to misbehave and either send off the wrong data or use memory after free or similar in the subsequent 'POST' request. The problem exists in the logic

Showing More

Finding for in resource Container | Container

First detected about 10 days ago, on 05/09/2026

Last detected about 9 days ago, on 06/09/2026

Asset Information

```
{  "id": "9d8b758d-8446-4194-bb20-15b89b1fe902"  "asset": {    "id": "9f4ba4ff-977e-4981-b4b9-1d21e1e88e75"    "name": "111122223333.dkr.ecr.us-east-1.amazonaws.com/aut- ..."    "type": {      "id": "1de194f8-e05c-4081-9998-c736e51b3004"
```

curl@7.64.0-4+deb10u2

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT



Memory corruption
POST-after-PUT confusion in libcurl



Part of a large backlog
108K image findings across ECR



Reaches production
qa-vision-api-main image



RECOMMENDED FIX

- ✓ Rebuild on a patched base (curl ≥ 7.86.0)
- ✓ Push updated tags
- ✓ ECR scan-on-push gate for Criticals

KIEM Security Graph: Excessive Permissions

HIGH

SECURITY GRAPH · 1 OF 2

RBAC paths across kube-system, argocd and argocd-apps



ArgoCD

Cluster-wide control



"*"

Wildcard resource grants



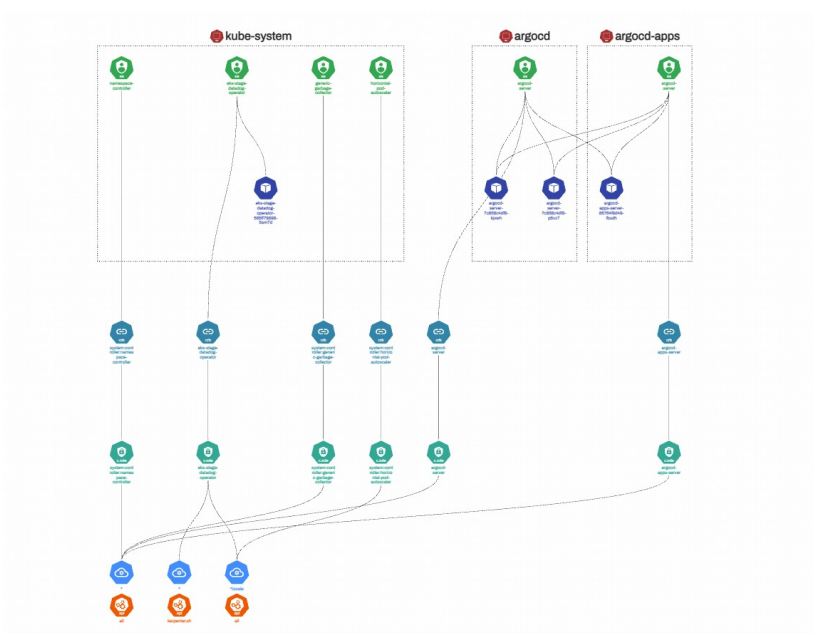
3

Namespaces in path



3

kube-system operators chained



AccuKnox platform, KIEM entitlement graph

RISK IMPACT



GitOps holds broad control

argocd-server can act cluster-wide



Wildcard grants

Can modify its own guardrails



Operators chained

datadog, GC & HPA share broad groups



RECOMMENDED FIX

- ✓ Replace wildcards with explicit resource lists
- ✓ Scope ArgoCD to its target namespaces

KIEM Security Graph: Cluster-Admin Roles

HIGH

SECURITY GRAPH · 2 OF 2

cluster-admin bindings across qdrant, kube-system and argocd



4

Cluster-admin holders



2

Workloads with admin reach



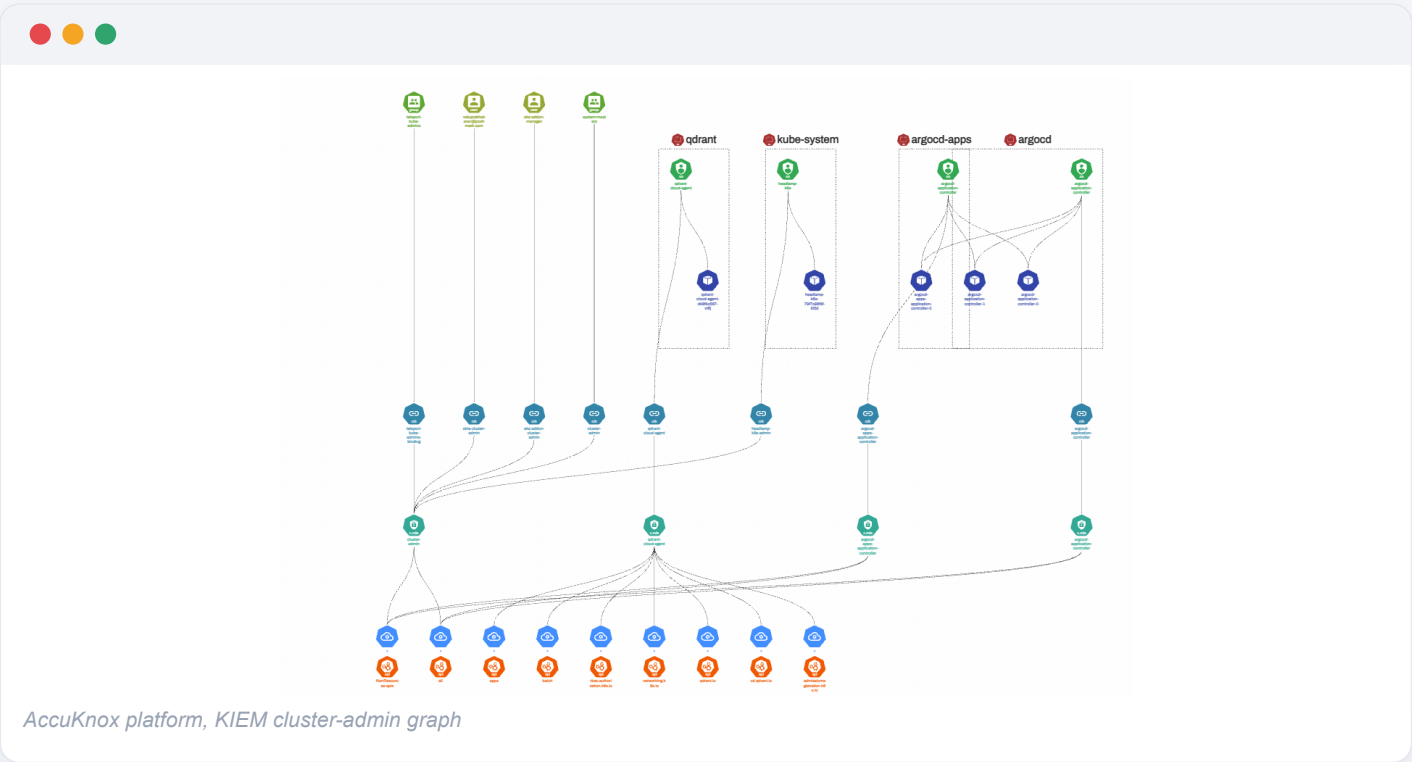
9

Wildcard API groups



Full

Control surface reachable



RISK IMPACT



Many cluster-admins

teleport, okta, eks-addon, system:masters



Workloads with admin

qdrant-cloud-agent, headlamp-ksa



Nine wildcard API groups

apps, batch, RBAC, admission & more



RECOMMENDED FIX

- ✓ Keep only break-glass human cluster-admin
- ✓ Purpose-built roles for qdrant & headlamp
- ✓ Justify every admission access

Container Image: Critical RCE in vLLM

CRITICAL

PLATFORM EVIDENCE

CVE-2026-22778 in vllm@0.11.0 across two ECR-hosted images

**4B → 8**
ASLR guesses after heap leak

**2**
Production images affected

**0.11 → 0.14.1**
Fixed upstream, not here

**11 days**
Since first detection

ACCUKNOX

Issues > Findings

Findings Summary

Findings

Rule Engine

Container Image Findings

Asset Type

Q Search

Findings

Unmanaged AI-ML App/Library: 328

Last Seen

Identification Number

2026-09-08 22:26:39

CVE-2026-22778

2026-09-08 22:27:36

CVE-2026-22778

2026-09-08 22:27:36

CVE-2026-48746

2026-09-08 22:28:56

CVE-2026-22778

1 row selected

1 - 2 of 2

vLLM: vLLM: Remote code execution via invalid image processing in the multimodal endpoint.: (vllm@0.11.0), CVE-2026-22778

Critical

📄 🔗 ✕

Age: 4 days

Severity: Critical

SLA: 10 days

CVE ID: CVE-2026-22778

Tickets Created: 0

Create Ticket

Ask AI

Description

Security Graph

Solution

Classification

Other Info

Raw Information

vLLM is an inference and serving engine for large language models (LLMs). From 0.8.3 to before 0.14.1, when an invalid image is sent to vLLM's multimodal endpoint, PIL throws an error. vLLM returns this error to the client, leaking a heap address. With this leak, we reduce ASLR from 4 billion guesses to ~8 guesses. This vulnerability can be chained a heap overflow with JPEG2000 decoder in OpenCV/FFmpeg to achieve remote code execution. This vulnerability is fixed in 0.14.1.

Show More

Finding for in resource

Unmanaged AI-ML App/Library | Unmanaged AI-ML App/Library

First detected

about 11 days ago, on 04/09/2026

Last detected

about 7 days ago, on 08/09/2026

Asset Information

{

"id": "3b968ab0-fb71-4d6a-9f47-cfad370303b1"

"asset": {

"id": "38ac5894-cdc9-4e2c-8a57-60586f1eff4"

"name": "pypi:vllm@0.11.0"

"type": {

Asset

pypi:vllm@0.11.0

Asset Type

Unmanaged AI-ML App/Library

Status

Active

Ignored

No

Location

vllm@0.11.0

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT

**Heap leak chains to RCE**
Plus a JPEG2000 decoder overflow

**Two production images**
2 of 326 unmanaged AI/ML findings

**Patch available**
vLLM 0.14.1 resolves it

**RECOMMENDED FIX**

✓ Rebuild both images on vllm ≥ 0.14.1

✓ Redeploy

✓ Gate Critical AI/ML CVEs on push

Security Graph: vLLM CVE Blast Radius

CRITICAL

SECURITY GRAPH

CVE-2026-22778 traced from package to every image that ships it

**1**
Package

**2**
Image paths

**1 fix**
Closes both paths

**108K**
Image-finding backlog



RISK IMPACT

- **One package, two images**
Both in the acme-prod ECR
- **Registry-wide pattern**
Not an isolated dependency
- **Directly actionable**
One base-image rebuild clears it

**RECOMMENDED FIX**

✓ Patch the shared base image once

✓ Re-scan both images; both nodes clear

Container Image: High CVEs in acl & addressable

HIGH

PLATFORM EVIDENCE

Two unrelated High-severity library CVEs on ACME Corp ECR images

The screenshot shows the AccuKnox interface for CVE-2026-54369. The title is "acl: Symlink traversal privilege escalation via libacl functions: (libacl1@2.3.1-3), CVE-2026-54369". The severity is High. The asset is "11112223333.dkr.ecr.us-east-1.amazonaws.com/acme-mcp-main-a6654a29e24a". The description states that before version 2.4.0, libacl contains a symlink traversal vulnerability in the libacl pathname-based functions. The interface also shows a table of findings with columns for Age, Severity, SLA, CVE ID, and Tickets Created.

The screenshot shows the AccuKnox interface for CVE-2026-35611. The title is "addressable: Addressable: Denial of Service via crafted URI templates: (addressable@2.8.8), CVE-2026-35611". The severity is High. The asset is "11112223333.dkr.ecr.us-east-1.amazonaws.com/server-ga-deployment-gate-SERVER-27658-base-acme-build". The description states that Addressable is an alternative implementation to the URI implementation that is part of Ruby's standard library. The interface also shows a table of findings with columns for Age, Severity, SLA, CVE ID, and Tickets Created.



CVE-2026-54369

acl symlink traversal

Routine ACL call becomes arbitrary file access

libacl1@2.3.1-3 · acme-mcp

✓ Upgrade libacl1 past 2.4.0



CVE-2026-35611

addressable ReDoS

One crafted URI template hangs the service

3,122 findings · deployment-gate images

✓ Upgrade addressable past 2.9.0

Cluster Finding: Images Missing Signature Verification

HIGH

PLATFORM EVIDENCE

C-0237 fails on stage-feed-service-interests, eks-stage-133

 **C-0237**
No signature check

 **8 days**
Open, still active

 **4,918**
Miscellaneous findings bucket

 **Stage**
Before production promotion

ACCUKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Cluster Findings Asset Category

Search

Findings

Configuration: 23

Miscellaneous: 4918

Last Seen Vulnerability Name

2026-09-09 01:15:33 Check if signature exists

2026-09-09 01:15:33 Check if signature exists

2026-09-09 01:15:33 Check if signature exists

2026-09-09 01:15:33 Check if signature exists

1 row selected 1 - 5 of 5

Check if signature exists High

Age 5 days Severity High SLA 15 days CVE ID C-0237 Tickets Created 0

Create Ticket Ask AI

Description Solution Classification Resource Manifest Raw Information

Ensures that all images contain some signature

Finding for in resource k8s_security_ReplicaSet | k8s_security_ReplicaSet

First detected about 11 days ago, on 04/09/2026

Last detected about 7 days ago, on 08/09/2026

Asset Information

```
{
  "id": "53d51bf4-8b0d-4799-94db-732965ca0d84",
  "asset": {
    "id": "3ea039ca-57d7-4aa5-ada3-3a0c9872a577",
    "name": "stage-feed-service-interests-66944dcdff",
    "type": {
      "id": "08d01e14-87b1-48ac-9ca0-d93175e15cd7",
      "name": "k8s_security_ReplicaSet",
      "category": "Miscellaneous",
      "alias": {

```

Asset stage-feed-service-interests-66944dcdff

Asset Type k8s_security_ReplicaSet

Status Active

Ignored No

Notes Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT

-  **No provenance guarantee**
Cannot verify images came from trusted builds
-  **Largest findings bucket**
Mostly supply-chain hygiene
-  **Unenforced since flagged**
First seen 04/09/2026



RECOMMENDED FIX

- ✓ Enable Cosign or Notation admission policy
- ✓ Require it in stage-feed-service before prod

CIS K8s Benchmark: Encryption Providers Not Set

MANUAL

PLATFORM EVIDENCE

Control 1.2.28, manual and unscored, on eks-stage-133

**1.2.28**
CIS control

**Plaintext**
Secrets in etcd

**7 days**
Open, still active

**113**
CIS K8s findings tracked

ACCUKNOX

Issues > Findings

Findings SummaryFindingsRule Engine

CIS K8s Benchmark Findings

Group by

Q Search

	Last Seen	Test Number
☐	2026-09-14 19:40:51	1.2.14
☐	2026-09-14 19:40:51	1.2.26
☒	2026-09-14 19:40:51	1.2.28
☐	2026-09-14 19:40:51	2.5
☐	2026-09-14 19:40:51	1.2.13
☐	2026-09-14 19:40:51	1.1.13
☐	2026-09-14 19:40:51	1.1.18

1 row selected1 - 20 of 113

1.2.28: Ensure that encryption providers are appropriately configured (Manual)Not Available

Age6 daysSeverityNot AvailableSLANATest Number1.2.28Tickets Created0

Create TicketAsk AI

DescriptionSolutionRaw Information

Ensure that encryption providers are appropriately configured (Manual)

Finding for in resourcek8s_CIS_Cluster | k8s_CIS_Cluster

First detectedabout 7 days ago, on 08/09/2026

Last detectedabout 1 day ago, on 14/09/2026

Asset Information

Asseteks-stage-133Asset Typek8s_CIS_ClusterStatusActiveIgnoredNoLocationeks-stage-133-Control Plane Security ...

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT

- **etcd data unencrypted**
Secrets & ConfigMaps stored as plaintext
- **Manual control**
Needs deliberate sign-off
- **Still open**
Seen 08/09, confirmed 14/09/2026

**RECOMMENDED FIX**

✓ Add EncryptionConfiguration (aescbc or KMS)

✓ Restart control-plane pods

✓ Re-encrypt existing etcd data

Container Image: Critical RCE via Babel Compiler

CRITICAL

PLATFORM EVIDENCE

CVE-2023-45133 in @babel/traverse@7.16.8 on content-review-store



734

Findings on one image



48

Critical in this registry

12 / 10 days

Open vs critical SLA: breached



7.23.2

Fixed @babel/traverse

Issues > Findings

Findings Summary Findings Rule Engine

Container Image Findings Risk Factor

Search

Findings

Critical: 24

Table with 2 columns: Last Seen, Identification Number

1 row selected 1 - 4 of 4

babel: arbitrary code execution: (@babel/traverse@7.16.8), CVE-2023-45133 Critical

Age: 4 days Severity: Critical SLA: 10 days CVE ID: CVE-2023-45133 Tickets Created: 0

Buttons: Create Ticket, Ask AI

Description: Babel is a compiler for writing JavaScript. In @babel/traverse prior to versions 7.23.2 and 8.0.0-alpha.4 and all versions of babel-traverse, using Babel to compile code that was specifically crafted by an attacker can lead to arbitrary code execution during compilation, when using plugins that rely on the path.evaluate() or path.evaluateTruthy() internal Babel methods. Known affected plugins are @babel/plugin-transform-runtime, @babel/preset-env when using its useBuiltins option; and any Show More

Asset: 11112223333 dkr.ecr.us-east-1.amazonaws.com/expconsole.stage-expconsole-main-965075d1

Asset Type: Container

Status: Active

Ignored: No

Location: @babel/traverse@7.16.8

Notes: Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT



Compile-time code execution

Via path.evaluate() & evaluateTruthy()



Heavy image

238 High, 336 Medium, 112 Low alongside



Past its SLA

First detected 04/09/2026

Wrench icon

RECOMMENDED FIX

Upgrade @babel/traverse past 7.23.2

Audit plugins using path.evaluate()

SECTION SIX

06

VM & Runtime Protection

App behaviour and Linux VM vulnerabilities

Learn more: help.accuknox.com/getting-started/runtime-sec-arch/

01 16K+ connections observed, audit mode only

02 KubeArmor alerts blocked at the host

03 33 hardening + 6 custom policies enforced

04 Critical VM CVEs and toxic combinations

Runtime Protection: App Behaviour

PLATFORM EVIDENCE

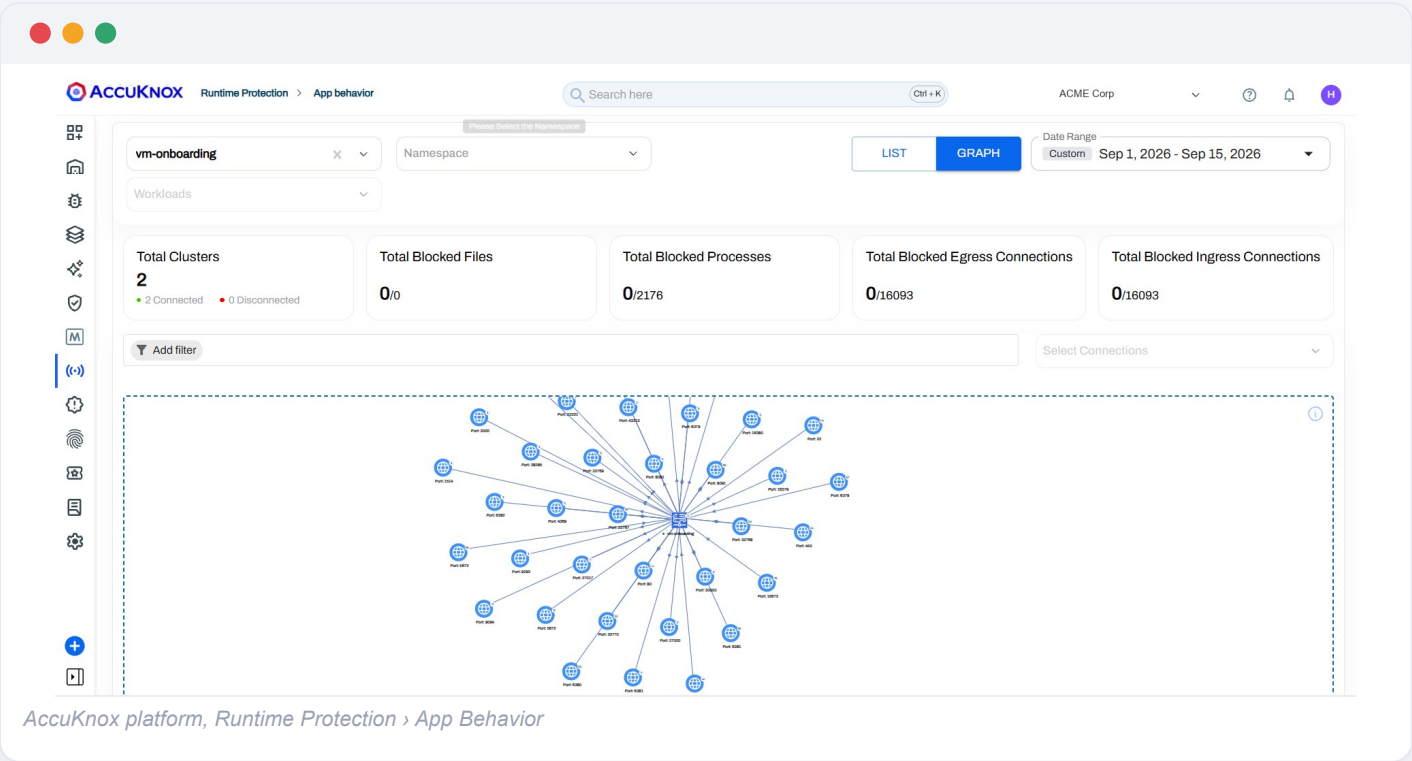
Observed flows on the vm-onboarding cluster, Sep 1 – 15, 2026

**16,093**
Egress connections

**16,093**
Ingress connections

**2,176**
Processes observed

**0**
Blocked (audit mode)



RISK IMPACT

- **Observed, not enforced**
Full visibility, zero blocking today
- **30+ ports in use**
22, 80, 443, 3000, 6379 & ephemeral

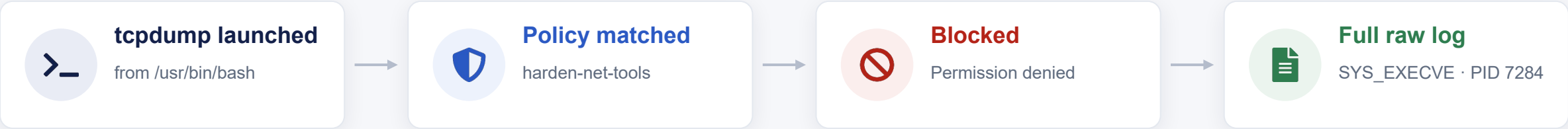
**RECOMMENDED FIX**

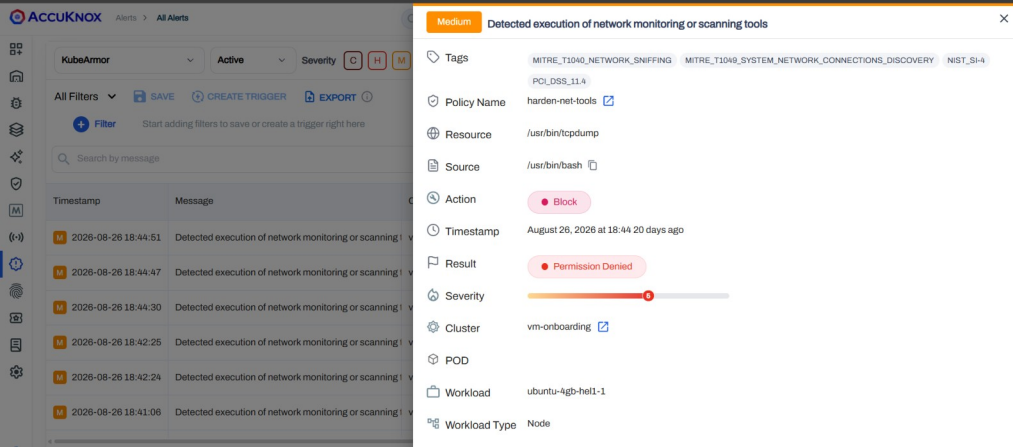
- ✓ Auto-generate least-privilege policies from baseline
- ✓ Move known-good set from audit to enforce
- ✓ Start with egress on the VM cluster

Cluster Alerts: Runtime Detection with Raw Logs

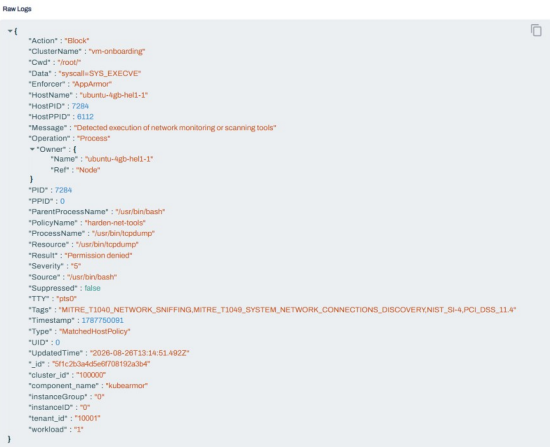
PLATFORM EVIDENCE

KubeArmor alert on vm-onboarding, blocked at the host





Detected execution of network monitoring tools



Raw log, full enforcement record

MAPPED TO

MITRE T1040

MITRE T1049

NIST SI-4

PCI DSS 11.4

✓ Export alerts as JSON to your SIEM; keep harden-net-tools on all VM nodes

Runtime Protection: Hardening & Custom Policies

PLATFORM EVIDENCE

Policies enforced across both clusters, Sep 15, 2026



33

Hardening policies enforced



6

Custom policies enforced



574

Policies tracked in total

Policy Name	Category	Status	Clusters
Audit use of network tools (v4)	Hardening	Active	vm-onboarding
Audit privilege escalation through use of sudo/su (v2)	Hardening	Active	vm-onboarding
Audit execution of package management tools (v4)	Hardening	Inactive	vm-onboarding
Audit system configuration files	Hardening	Inactive	vm-onboarding
Audit credential modification	Hardening	Inactive	vm-onboarding
Audit loading of kernel modules at boot/system connect	Hardening	Inactive	vm-onboarding
Audit use of ssh from sshd@cloud	Hardening	Inactive	vm-onboarding

Policy Name	Category	Status	Clusters
Audit use of network tools (v4)	Hardening	Active	vm-onboarding
Audit privilege escalation through use of sudo/su (v2)	Hardening	Active	vm-onboarding
Audit execution of package management tools (v4)	Hardening	Inactive	vm-onboarding
Audit system configuration files	Hardening	Inactive	vm-onboarding
Audit credential modification	Hardening	Inactive	vm-onboarding
Audit loading of kernel modules at boot/system connect	Hardening	Inactive	vm-onboarding
Audit use of ssh from sshd@cloud	Hardening	Inactive	vm-onboarding

Policy Name	Category	Status	Clusters
qdrant-cluster-manager	Custom	Active	eks-stage-125
qdrant-operator-v2	Custom	Active	eks-stage-125
qdrant-1000000-2000-0000-qdrant-client	Custom	Active	eks-stage-125
qdrant-cluster-manager	Custom	Active	eks-stage-125



harden-net-tools

v4 · vm-onboarding

ACTIVE

Blocks bettercap & masscan



harden-su-access

v2 · vm-onboarding

ACTIVE

Blocks su/sudo escalation · severity 8



qdrant-cluster-manager

Custom · eks-stage-133

ACTIVE

Scopes ingress to monitoring & qdrant

Linux VM: Critical CVE in PyYAML

CRITICAL

PLATFORM EVIDENCE

CVE-2020-14343 on stage-api-1-use1-c



CVE-2020-14343
Arbitrary code execution

7 / 10 days
Open vs critical SLA



92
Findings on this host



≥ 5.4
Fixed PyYAML version

ACCUKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Linux VM Vulnerability Findings

Group by

Search

Last Seen

Identification Number

2026-09-15 12:34:49

CVE-2020-14343, CVE-2020-14343

2026-09-15 12:47:22

CVE-2020-14343, CVE-2026-41242, CVE-2026-41242

2026-09-15 12:47:22

CVE-2024-24790

2026-09-15 12:47:22

CVE-2024-24790

2026-09-15 12:34:49

CVE-2024-24790

2026-09-15 12:34:49

CVE-2025-14813, CVE-2025-14813

2026-09-15 12:47:22

CVE-2025-14813, CVE-2025-14813

1 row selected 1 - 20 of 92

PyYAML: incomplete fix for CVE-2020-1747: (PyYAML@3.12), CVE-2020-14343

Critical

Create Ticket Ask AI

Age	Severity	SLA	CVE ID	Tickets Created
7 days	Critical	10 days	CVE-2020-14343	0

Description

Solution

Classification

Other Info

Raw Information

A vulnerability was discovered in the PyYAML library in versions before 5.4, where it is susceptible to arbitrary code execution when it processes untrusted YAML files through the full_load method or with the FullLoader loader. Applications that use the library to process untrusted input may be vulnerable to this flaw. This flaw allows an attacker to execute arbitrary code on the system by abusing the python/object/new constructor. This flaw is due to an incomplete fix for CVE-2020-1747.

Show More

Finding for in resource

virtual_machine | virtual_machine

First detected

about 7 days ago, on 08/09/2026

Last detected

today, on 15/09/2026

Asset Information

```
{  "id": "50e40f68-61ac-4767-b47d-779177e08da9"  "asset": {    "id": "165fa30c-25a5-4581-94d2-5c5bfe186936"    "name": "stage-api-1-use1-c.aws.acme.net"    "type": {      "id": "6f2ad0f9-c5d7-43ca-818c-b42b311e85ba"
```

Asset

stage-api-1-use1-c.aws.acme.net

Asset Type

virtual_machine

Status

Active

Ignored

No

Location

PyYAML@3.12

Notes

Add Comments and Press Ctrl + Enter to Submit

AccuKnox platform, live finding evidence

RISK IMPACT

Code execution on parse
full_load / FullLoader on untrusted YAML

Incomplete prior fix
CVE-2020-1747 patch left a path open

Live application host
Staging API virtual machine

RECOMMENDED FIX

- ✓ Upgrade PyYAML to 5.4+
- ✓ Rebuild images pinning 3.12
- ✓ Use safe_load for untrusted input

AccuKnox · Secure Code to Cognition™ · Confidential, ACME Corp internal use

43

Linux VM: High CVE in python-cryptography

HIGH

PLATFORM EVIDENCE

CVE-2023-50782 on stage-api-1-use1-c



CVE-2023-50782

Bleichenbacher timing oracle



3.4.8

Installed version



≥ 42.0.0

Fixed version



1,389

VM findings on this host

AccuKnox platform, live finding evidence

python-cryptography: Bleichenbacher timing oracle attack against RSA decryption - incomplete fix for CVE-2020-25659: (cryptography@3.4.8), CVE-2023-50782

Age: 7 days, Severity: High, SLA: 15 days, CVE ID: CVE-2023-50782, Tickets Created: 0

Description: A flaw was found in the python-cryptography package. This issue may allow a remote attacker to decrypt captured messages in TLS servers that use RSA key exchanges, which may lead to exposure of confidential or sensitive data.

Finding for in resource: virtual_machine | virtual_machine

First detected: about 7 days ago, on 08/09/2026

Last detected: today, on 15/09/2026

Asset Information

```
{
  "id": "50e40f68-61ac-4767-b47d-779177e08da9"
  "asset": {
    "id": "165fa30c-25a5-4581-94d2-5c5bfe186936"
    "name": "stage-api-1-use1-c.aws.acme.net"
    "type": {
      "id": "6f2ad0f9-c5d7-43ca-818c-b42b311e85ba"
      "name": "Virtual Machine"
    }
  }
}
```

RISK IMPACT



TLS traffic decryptable

RSA key exchange is exploitable



Data in transit exposed

Credentials & API payloads



Top High in a big backlog

1,389 VM findings on the host



RECOMMENDED FIX



Upgrade python-cryptography to 42.0.0+



Disable RSA key exchange, prefer ECDHE

Linux VM: Critical Directory Traversal in rubyzip

CRITICAL

PLATFORM EVIDENCE

CVE-2017-5946 on stage-api-1-use1-b



CVE-2017-5946
Zip path traversal



9 years
Old, still unpatched



0.9.9 → 1.2.1
Installed vs fixed



Day 0
Caught the day it appeared

ACCUKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Linux VM Vulnerability Findings Vulnerability Na

Q Search

Findings

rubygem-rack: crafted requests can cause shell escape

rubygem-rubyzip: Directory traversal in the Zip::File component

Last Seen

Identification Num

2026-09-15 12:47:22 CVE-2017-5946, C

2026-09-15 12:34:49 CVE-2017-5946, C

1 - 2 of 2

1 row selected 41 - 49 of 49

rubygem-rubyzip: Directory traversal in the Zip::File component: (rubyzip@0.9.9), CVE-2017-5946

Age

Severity

SLA

CVE ID

Tickets Created

7 days

Critical

10 days

CVE-2017-5946

0

Description

Solution

Classification

Other Info

Raw Information

The Zip::File component in the rubyzip gem before 1.2.1 for Ruby has a directory traversal vulnerability. If a site allows uploading of .zip files, an attacker can upload a malicious file that uses "../" pathname substrings to write arbitrary files to the filesystem.

Finding for in resource

virtual_machine | virtual_machine

First detected

about 7 days ago, on 08/09/2026

Last detected

today, on 15/09/2026

Asset Information

"id" : "c7425378-322a-4618-adbf-f3dee8d75175"

"asset" : {

"id" : "a0bc5a2e-1b50-4f55-a09b-6455b5baa372"

"name" : "stage-api-1-use1-b.aws.acme.net"

"type" : {

"id" : "bf2ad0f9-c5d7-43ca-818c-b42b311e85ba"

"name" : "virtual_machine"

Create Ticket

Ask AI

Asset

stage-api-1-use1-b.aws.acme.net

Asset Type

virtual_machine

Status

Active

Ignored

No

Location

rubyzip@0.9.9

Notes

Add Comments and Press Ctrl + Enter to Submit

RISK IMPACT



Upload = arbitrary file write
"./." paths escape the target folder



Long-known CVE
8 major versions behind the fix



Detected immediately
First seen 15/09/2026



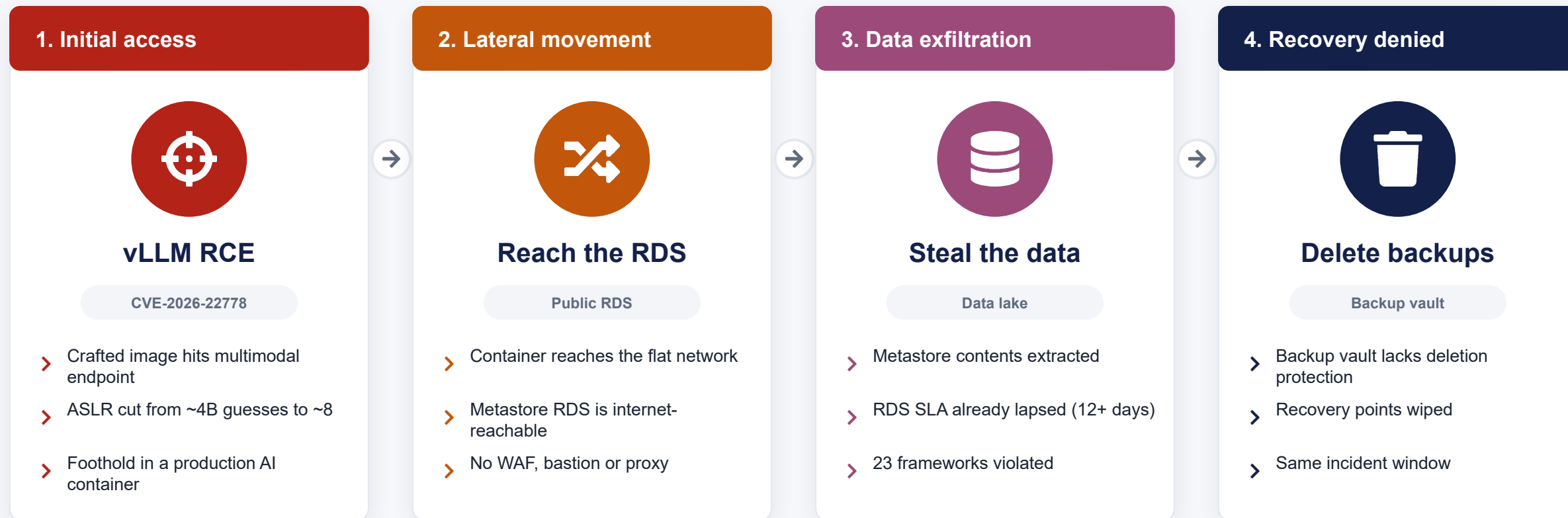
RECOMMENDED FIX

- ✓ Upgrade rubyzip to 1.2.1+ and rebuild
- ✓ Validate extracted paths as defence-in-depth

Attack Path: AI Workload Compromise to Data Loss

HOW THE FINDINGS CONNECT

Four unrelated findings chain into one incident on account 111122223333



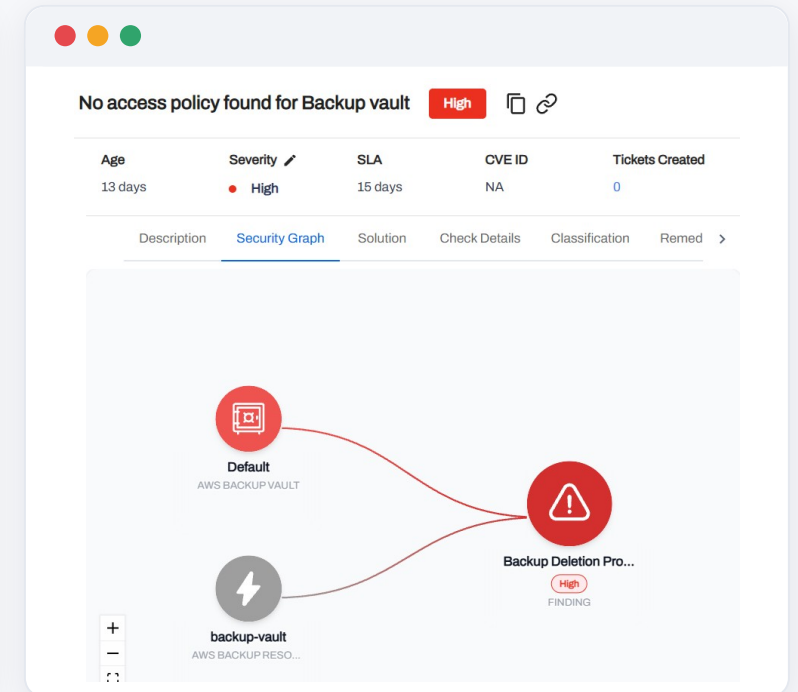
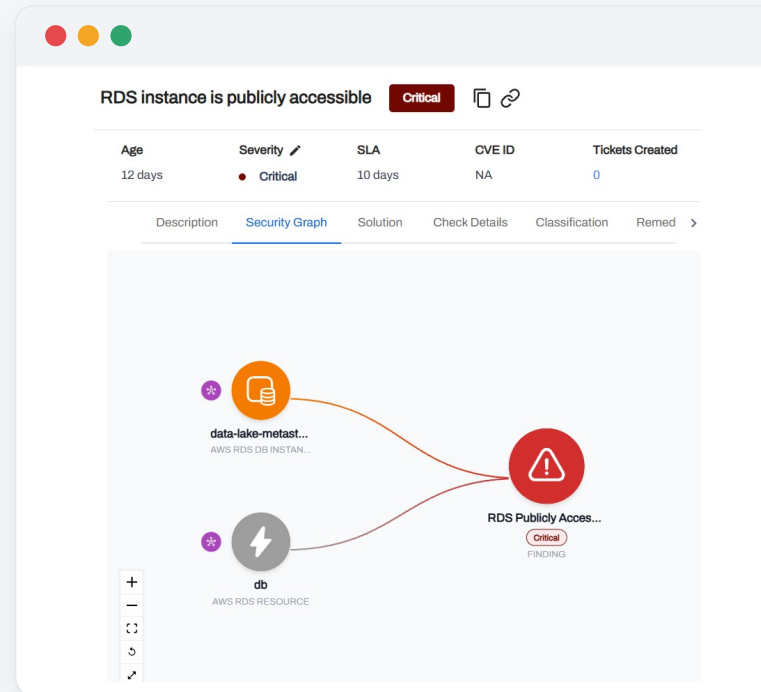
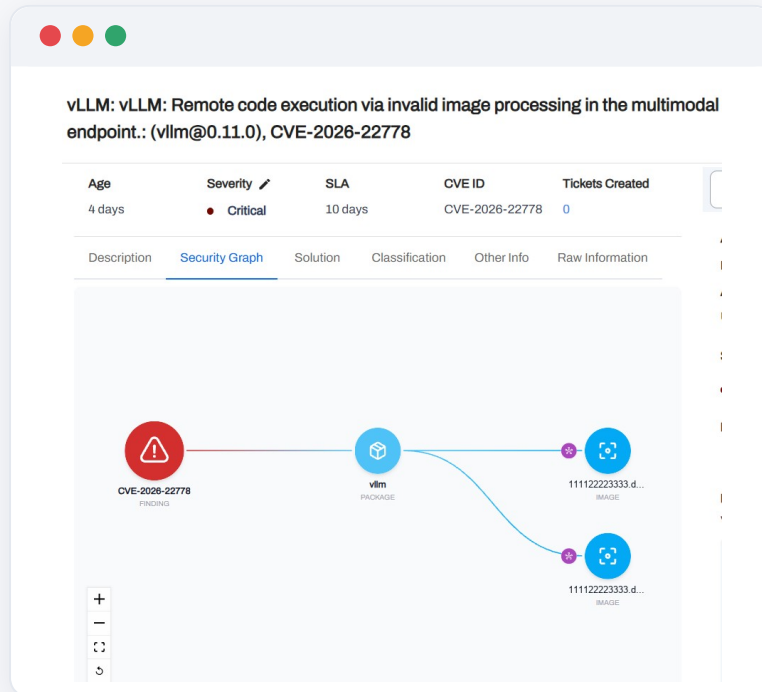
Result: unrecoverable data loss, not just a breach

Break the chain at any stage: patch vLLM, make RDS private, lock the vault.

Attack Path: Security Graph Evidence

PLATFORM EVIDENCE

The connected-asset graphs behind each stage of the chain



1 Stage 1 · Initial access

vLLM package fans out to both ECR images

2-3 Stages 2-3 · Data exposure

RDS: one internet-reachable resource, no control in path

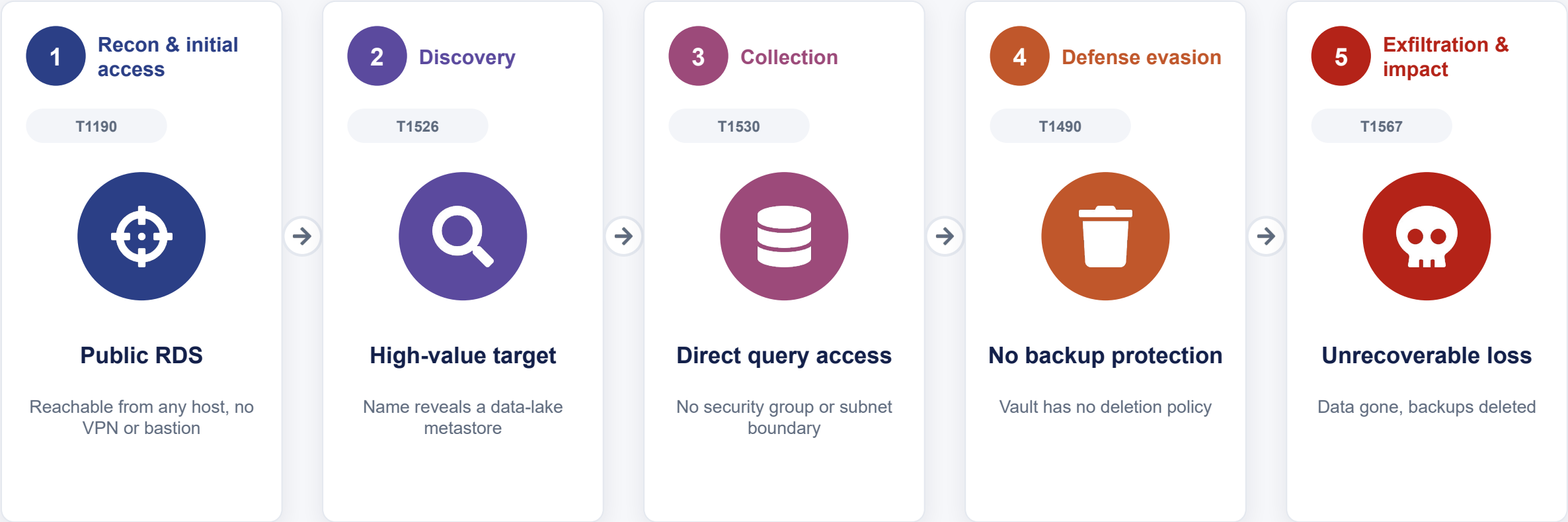
4 Stage 4 · Recovery denied

Vault and backup share one unprotected path

Toxic Combination (Cloud): Public Database to Unrecoverable Loss

TOXIC COMBINATION · MITRE ATT&CK MAPPED

AWS account 111122223333 · AccuKnox CSPM evidence

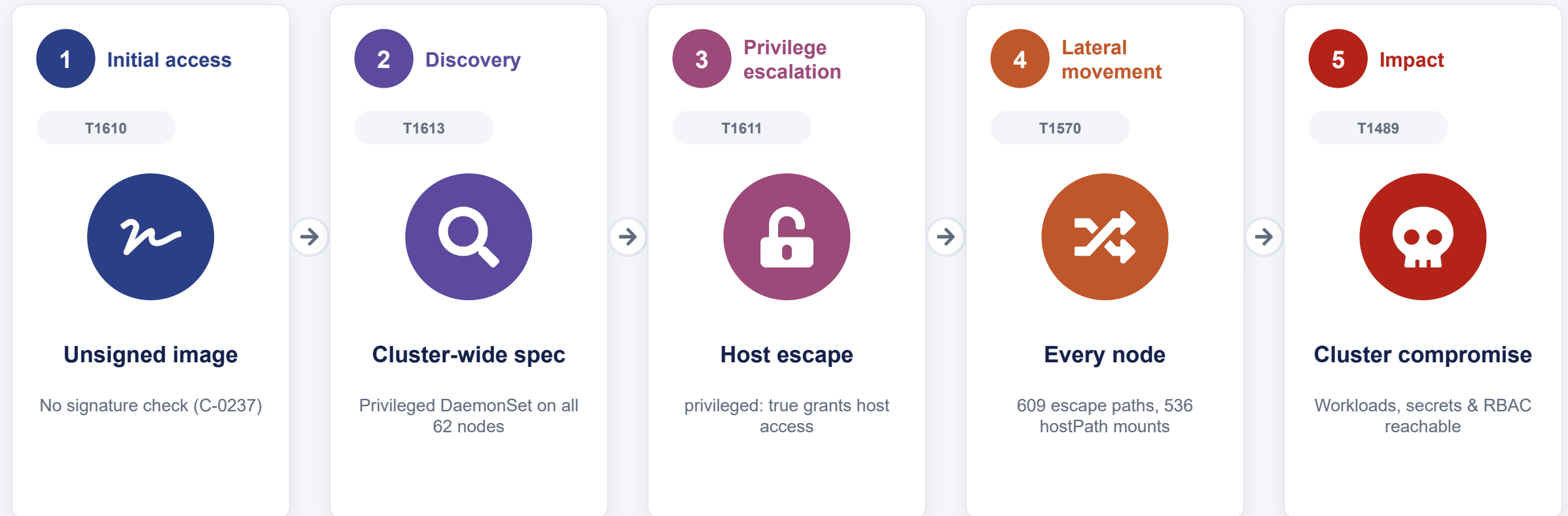


Two cloud findings, one unrecoverable outcome.

Toxic Combination (Cluster): Unsigned Image to Cluster Compromise

TOXIC COMBINATION · MITRE ATT&CK MAPPED

eks-stage-133 (EKS) · AccuKnox KSPM evidence

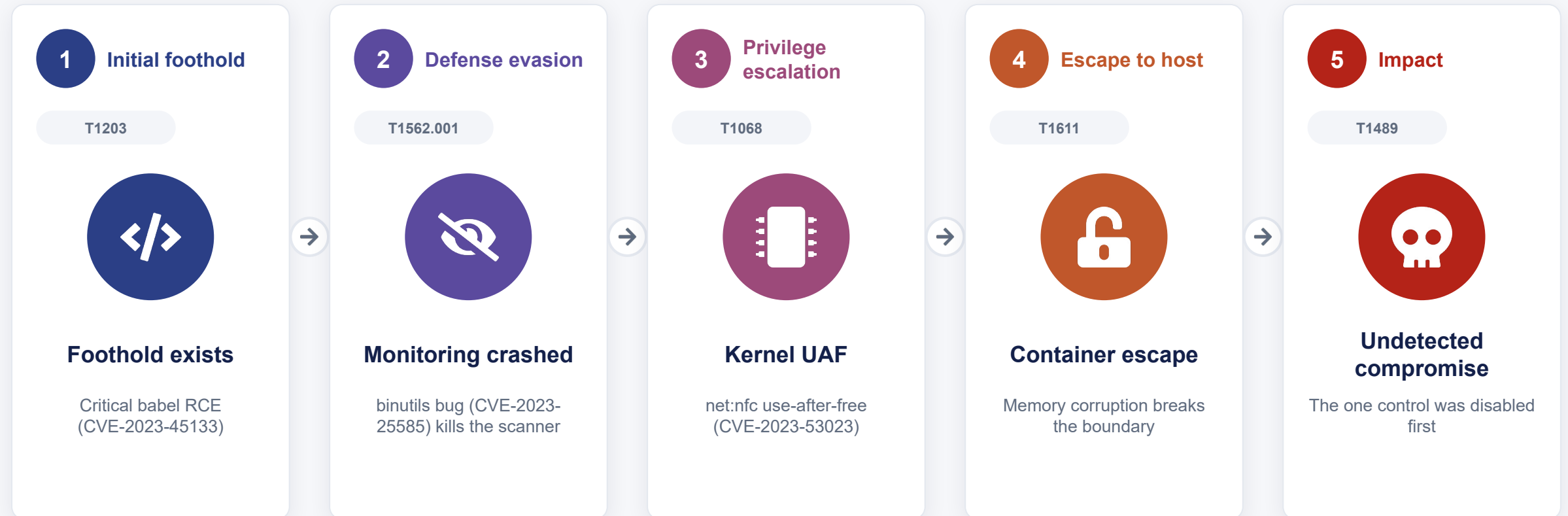


One High finding plus a DaemonSet pattern, and no signature gate to stop it.

Toxic Combination (Registry): Crash Bug Masks Kernel Compromise

TOXIC COMBINATION · MITRE ATT&CK MAPPED

Registry content-review-store · AccuKnox container scanning evidence

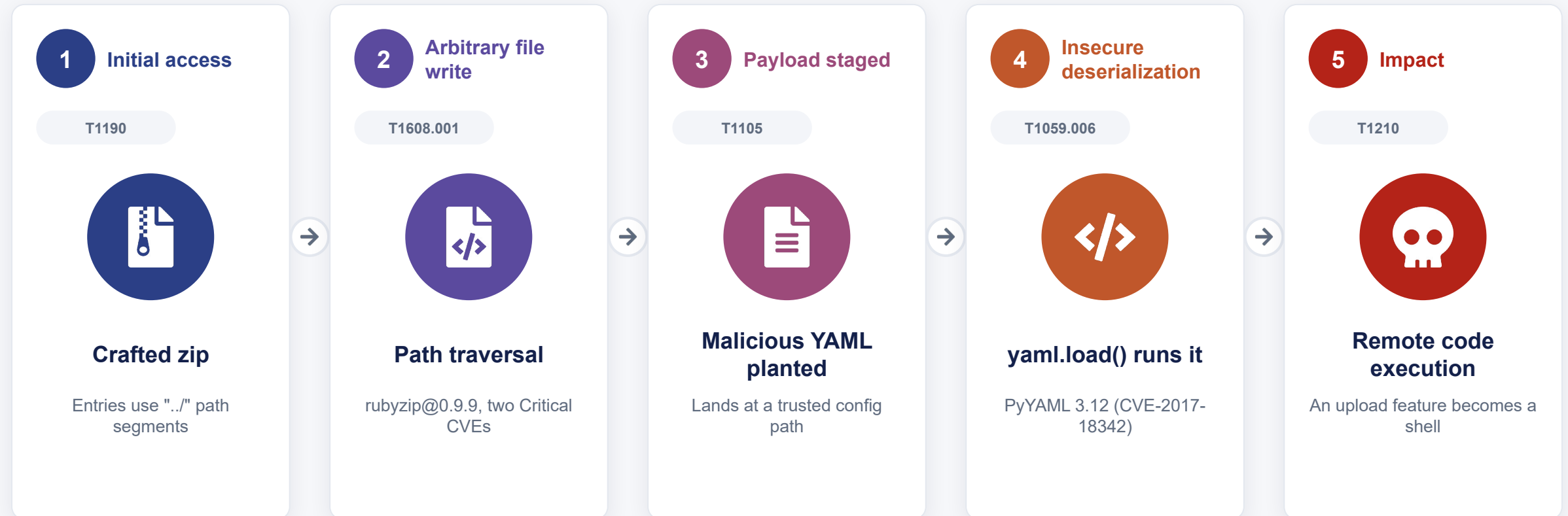


A Medium and a High, chained, defeat the control meant to catch them.

Toxic Combination (VM): Zip Upload to Remote Code Execution

TOXIC COMBINATION · MITRE ATT&CK MAPPED

stage-api-1-use1-b · AccuKnox VM scan evidence



Two Critical CVEs on one host reach RCE with no other access needed.

SECTION SEVEN

07

Investigation Report

AI-correlated deep dives on two priority findings

- 01 One cloud and one Kubernetes finding
- 02 Severity, evidence & correlation cross-checked
- 03 Root cause with an asset-specific fix
- 04 Compounding risk checked, not assumed

Investigation Report: EC2 Missing SSM Enrollment

HIGH

AI-CORRELATED INVESTIGATION

Finding 3f9a1c7e · unnamed EC2 instance, us-west-2

AccuKNOX

Issues > Findings

Findings Summary Findings Rule Engine

Cloud Findings Risk Factor

Search

Findings

High: 12

Last Seen	Finding Name
2026-09-24 08:15:27	EC2 Instance: i-08
2026-09-24 08:15:27	EC2 Instance: i-00
2026-09-24 08:15:27	EC2 Instance: i-08
2026-09-24 08:15:27	EC2 Instance: i-08

1 row selected 1 - 3 of 3

EC2 Instance: i-0abc123def4567890 is not managed by AWS Systems Manager High

Age: 6 days

Severity: High

SLA: 15 days

CVE ID: NA

Tickets Created: 0

Create Ticket

Ask AI

Asset

CNAPP

Asset Type: aws_ec2_instance

Status: Active

Ignored: No

Location: us-west-2

Notes

EC2 finding 3f9a1c7e-4ea6-4543-8cec-8cf4a7d7f478

- Finding ID: 3f9a1c7e-4ea6-4543-8cec-8cf4a7d7f478
- Vulnerability ID: bd700a12-0c98-414e-baad-8602756f9561
- Asset ID and name: fc4e14f3-7e57-42ef-80e0-cc7f3a2d61ef, Unnamed EC2 instance
- Status: Active
- Original investigation flag: false
- Source severity: High
- Verified new severity: High
- Severity update verification: risk_factor_match=true; description_preserved=true; solution_preserved=true
- CVE or GHSA: []
- CVSS: Not present
- Package and version: Not present Not present
- Exploit availability: Not present
- Reason for severity change or no-change: No numeric CVSS was returned. No open public port evidence.

What We Found

- Public-port evidence: No public-IP scan was applicable.
- Finding, vulnerability, and EC2 asset detail were reviewed before publication.

AccuKnox platform, investigation report evidence

INVESTIGATION VERDICTS

- No CVE, still High**
A control gap, so no exploit data expected
- Public exposure ruled out**
Risk is manageability, not internet access
- Root cause: governance**
Instance not enrolled as SSM managed
- Repeatable fix**
Same fix for every unenrolled instance

RECOMMENDATION

✓

Enroll i-0abc123def4567890 in SSM

✓

Validate with aws ec2 describe-instances

Investigation Report: EKS Secrets Not Encrypted

HIGH

AI-CORRELATED INVESTIGATION

Finding b52d08e4 · cluster eks-sre-133

Issues > Findings

Findings Summary Findings Rule Engine

Cloud Findings Risk Factor

Search

Findings

1 row selected 1 - 3 of 3

Envelope encryption of Kubernetes secrets is not enabled for cluster "eks-sre-133" High

Age	Severity	SLA	CVE ID	Tickets Created
21 days	High	15 days	NA	0

Create Ticket

Ask AI

Asset

eks-sre-133

Asset Type

aws_eks_cluster

Status

Active

Ignored

No

Location

us-east-1

Notes

Add Comments and Press Ctrl + Enter to Submit

Investigation Report

Description

- Finding ID: b52d08e4-8655-42b5-9ega-6aocb0354e3b
- Vulnerability ID: 894143f6-dee9-4b35-b667-456b38b8229e
- Asset ID: be7e3352-41c8-48f3-a4b6-671eeda5e66d
- Asset name: eks-sre-133
- Cloud provider: aws
- Cluster type: EKS
- Source data stream: KSPM
- Status: Active
- Original investigation_flag: false
- Source severity: High
- Researched new severity: High
- CVE/GHSA: Not present in source data
- CVSS: Not present in source data
- Correlated Findings:

Solution

Check Details

AccuKnox platform, investigation report evidence

INVESTIGATION VERDICTS

- Correlation ran**
3 related Lows did not change severity
- Compounding check run**
Identity, workload & posture combos: none
- Blind spots flagged**
Image & KIEM streams not ingested
- Root cause**
No envelope encryption for Secrets

RECOMMENDATION

✓

Apply the remediation manifest via kubectl

✓

Add least-privilege RBAC & NetworkPolicies

SECTION EIGHT

08

Executive Risk Prioritization

How 872 findings became a 360-item action queue

- 01 1,371 investigation reports reviewed
- 02 41 findings raised after attack-scenario review
- 03 Critical 7 → 5, High 359 → 373
- 04 360 Critical/High findings to fix first

Risk-Prioritization Funnel & Severity Shifts

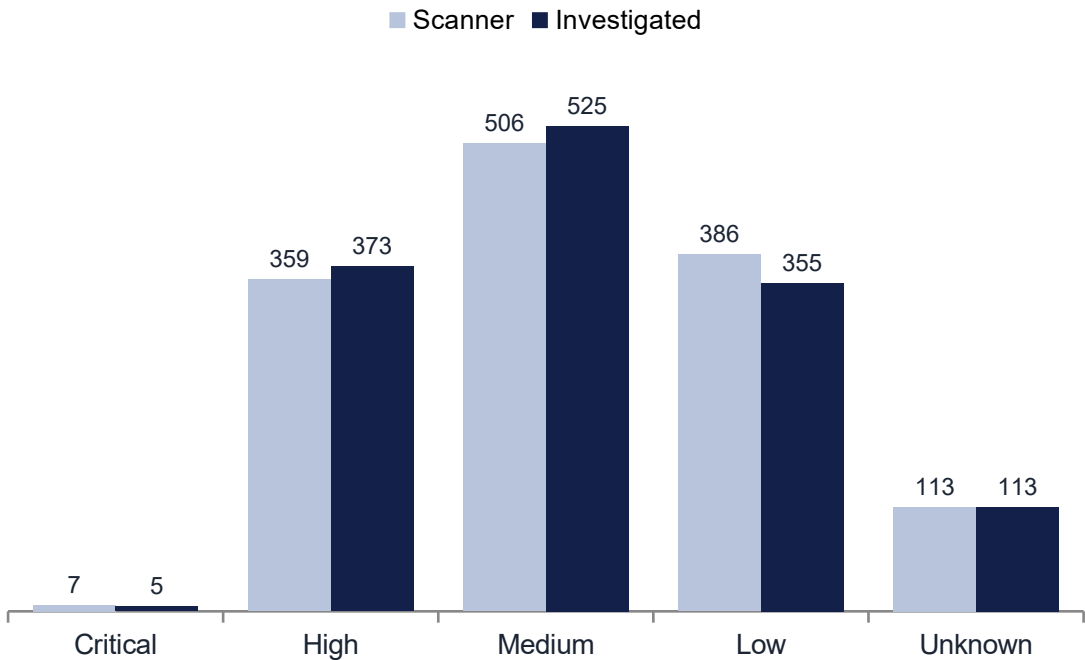
EXECUTIVE RISK PRIORITIZATION

1,371 investigation reports across Cluster, EC2 and KIEM

FROM SCANNER OUTPUT TO ACTION QUEUE



SEVERITY: SCANNER VS INVESTIGATED



-2

Critical

+14

High

+41

Raised by attack context

-6

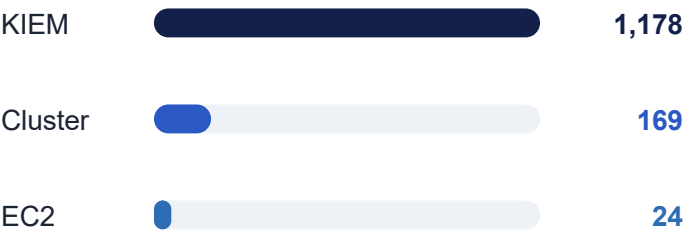
Reduced by exploitability

By Stream, Key Reductions & Remaining Risk

EXECUTIVE RISK PRIORITIZATION

Where the 360-item Critical/High queue concentrates

REPORTS BY STREAM

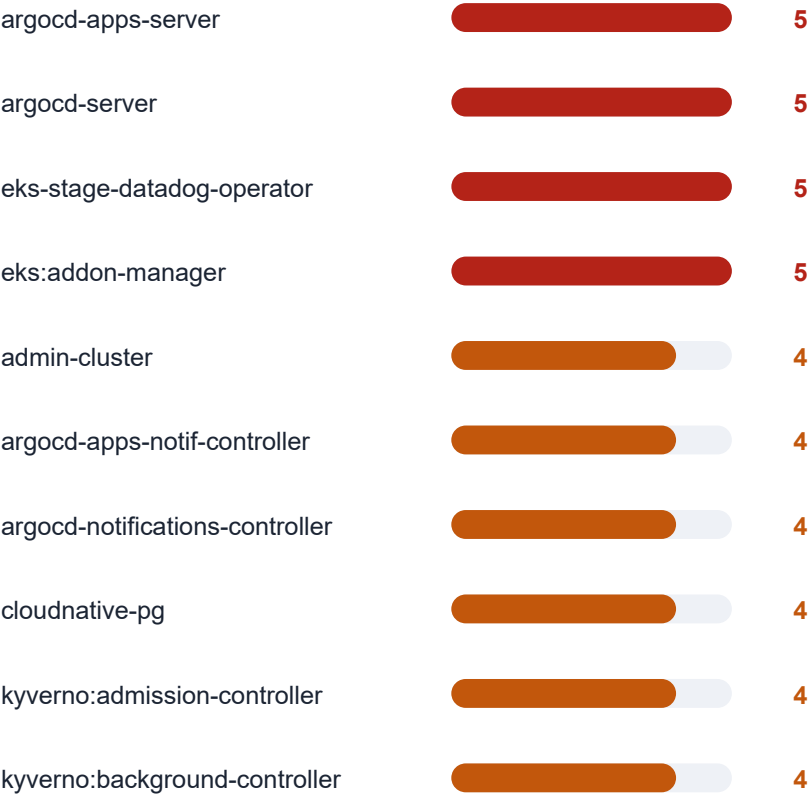


CRITICAL/HIGH NOW



KIEM identity context drives almost the entire remaining queue.

TOP REMAINING CRITICAL/HIGH ASSETS



DOWNGRADED CRITICAL → LOW

- ✓ tigera-operator
- ✓ admin-cluster
- ✓ kubera-y-operator
- ✓ edit-cluster
- ✓ eks-stage-datadog-operator
- ✓ system:aggregate-to-edit-cluster

Fix the 360 first, then Medium findings with cluster-wide correlation.

SECTION NINE

09

Assistive Remediation

Ask AI & Agent Z: from finding to fix

Learn more: help.accuknox.com/agentz/

- 01 One-click Ask AI on every finding
- 02 Agent Z runs from chat, API or schedule
- 03 Every action checked and audited
- 04 Automation, not more headcount

Agent Z Workflow: One Request, Many Steps

ASSISTIVE REMEDIATION

How the agent replaces the manual finding-to-ticket loop



“Triage the 48 Critical container-image findings on content-review-store and file tickets”



01

Reads the finding

Severity, asset, package version



02

Checks dependencies

Every image or service that ships it



03

Proposes the fix

Root cause & ready-to-paste code



04

Files & reports back

Ticket opened, fix path confirmed

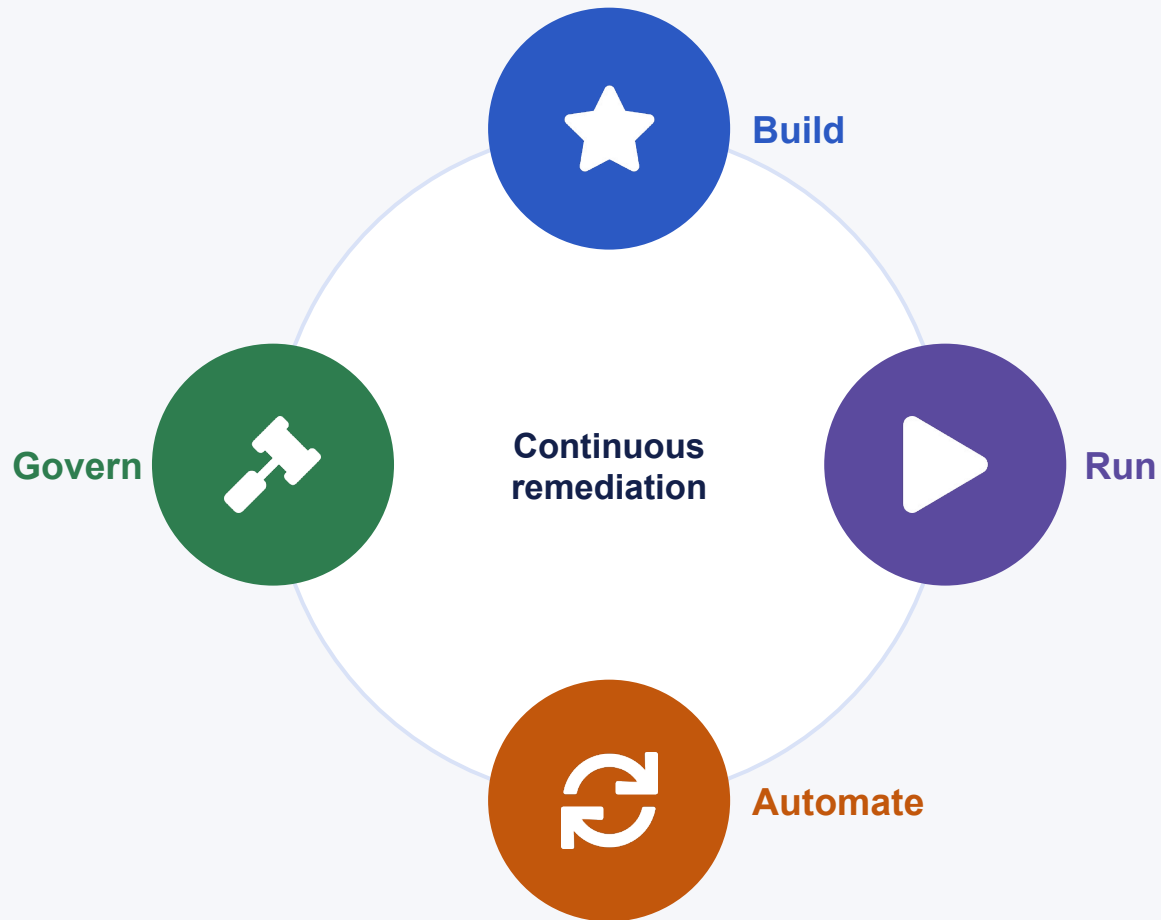
108K

container-image findings across ACME Corp ECR: one request replaces reading, researching, ticketing and chasing each one.

Agent Z Lifecycle: Build, Run, Automate, Govern

ASSISTIVE REMEDIATION

A continuous remediation loop across CSPM, KSPM and registry findings



Build
Describe the job once

Run
Chat, API or timer

Automate
On every scan or cron

Govern
Checked & audited

Critical 7 → 5 in the investigation reports is this loop at work.

SECTION TEN

10

POC Summary & Next Steps

What AccuKnox proved & the remediation roadmap

Learn more: help.accuknox.com/getting-started/cwpp-prereq/

- 01 What we assessed, found and proved
- 02 Roadmap: Week 1, 30, 60 and 90 days
- 03 Production onboarding, gates, CDR & Ask AI

POC Summary: What AccuKnox Demonstrated

POC OUTCOME

AWS CSPM + KSPM + VM · Sep 1 – Sep 15, 2026

✓ **POC completed: full CSPM, KSPM and VM visibility, risk quantification and compliance across the ACME Corp estate**

WHAT WE ASSESSED

7.97K Cloud findings, 2 AWS accounts

16.9K Kubernetes findings, 2 clusters

108K Container image CVEs

37 Compliance frameworks

WHAT WE FOUND

7 Critical cloud: RDS, Docker, VNC

122 Privileged containers in EKS

609 Container escape paths

1.48K VM vulnerability findings

WHAT WE PROVED

 **Unified**
Cloud, K8s, images & VMs

 **Prioritised**
Ranked by severity & blast radius

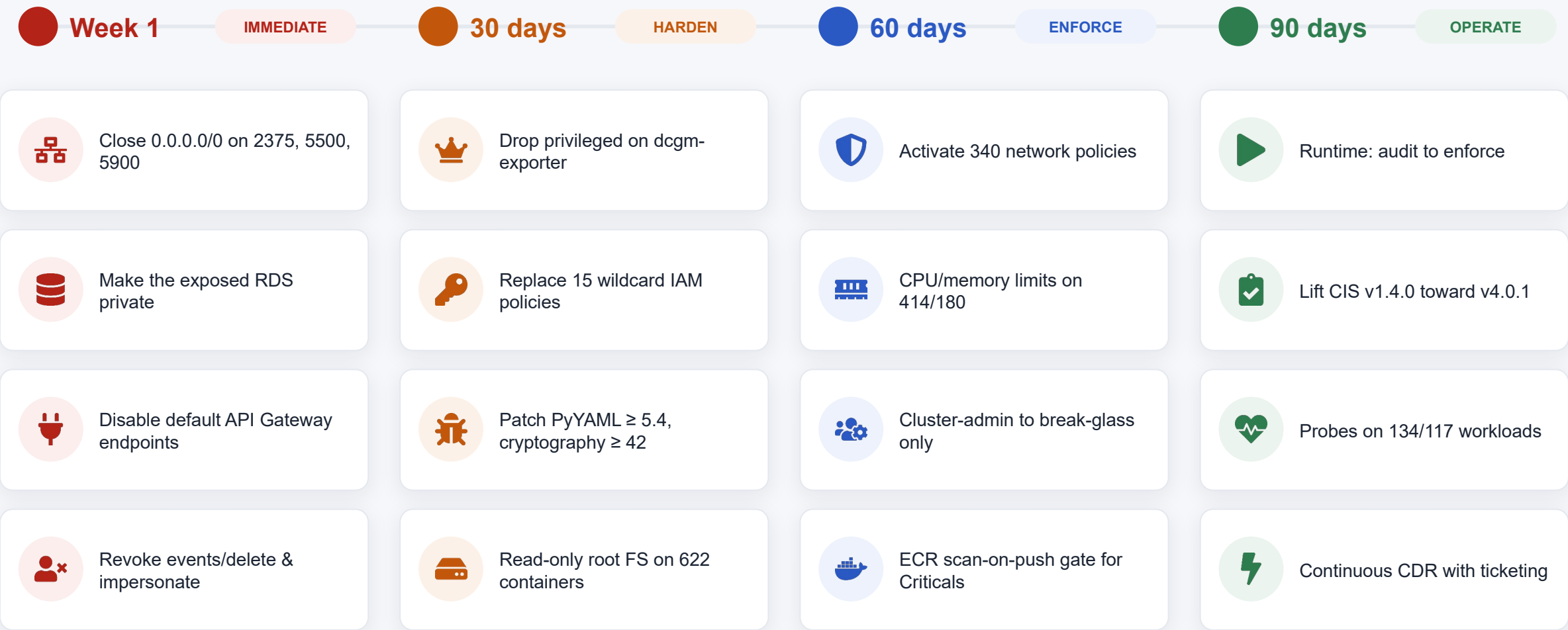
 **Ask AI**
Guided fixes, one-click tickets

 **Continuous**
Daily re-scan, not a one-off audit

Recommended Remediation Roadmap

NEXT 90 DAYS

Prioritised by severity, exploitability and compliance impact



Ready to secure your cloud & Kubernetes estate?

The POC proved unified visibility, risk quantification and compliance across ACME Corp's AWS accounts, clusters and VMs. Next step: production deployment.



Schedule production onboarding

Full multi-cluster rollout



Define remediation gates

Findings into CI/CD & ticketing



Enable CDR & Ask AI

Runtime enforcement, AI-guided fixes